Criptografía, CSIRT y Malware

350 preguntas de opción múltiple, nivel intermedio y avanzado

Material de estudio basado en los apuntes de Introducción a la Ciberseguridad, IC 2026.

La solución de cada pregunta incluye la opción correcta, una explicación y la referencia al material de estudio.

Criptografía	**66 preguntas**
CSIRT	**160 preguntas**
Malware	**124 preguntas**

Materiales utilizados

- 03 Conceptos Básicos.pdf (fundamentos vinculados a CSIRT)
- 04 Cripto parte 1.pdf
- 05 CSIRT - Recursos de Internet.pdf
- 06 encabezados_smtp.pdf
- 07 CSIRT - Gestión de incidentes.pdf
- 08 Analisis_de_malware.pdf

No incluye reversing, ensamblador, explotación ni información administrativa de cursada.

Criptografía

Preguntas de opción múltiple · Una única respuesta correcta · Justificá tu elección.

001. ¿Qué diferencia esencial separa Base64 de un cifrado?

Respuesta correcta: E) Base64 representa datos sin aportar secreto criptográfico

Explicación: La codificación Base64 es reversible sin clave secreta.

Fuente: 04 Cripto parte 1.pdf · págs. 7-8

002. ¿Cómo se representa en ASCII decimal la letra C mayúscula?

Respuesta correcta: A) 67

Explicación: La letra C es 0x43, equivalente a 67 decimal.

Fuente: 04 Cripto parte 1.pdf · págs. 7-8

003. ¿Cuál es la representación hexadecimal de la letra i minúscula en ASCII?

Respuesta correcta: E) 0x69

Explicación: ASCII i minúscula equivale a decimal 105, hexadecimal 69.

Fuente: 04 Cripto parte 1.pdf · págs. 7-8

004. ¿Qué característica distingue ASCII estándar de Unicode?

Respuesta correcta: E) ASCII básico define 128 valores; Unicode abarca muchos más caracteres

Explicación: ASCII estándar es de 7 bits y Unicode cubre repertorios mucho mayores.

Fuente: 04 Cripto parte 1.pdf · págs. 7-8

005. Si en un binario aparece el byte hexadecimal 0x41, ¿qué carácter ASCII representa?

Respuesta correcta: E) A

Explicación: 0x41 corresponde al carácter A mayúscula.

Fuente: 04 Cripto parte 1.pdf · págs. 7-8

006. ¿Qué operación describe la criptografía y no una simple codificación?

Respuesta correcta: D) Transformar datos bajo un algoritmo y una clave secreta o pública para restringir su lectura

Explicación: El cifrado utiliza claves para proteger la confidencialidad de la información.

Fuente: 04 Cripto parte 1.pdf · págs. 11-13

007. Si César ROT3 transforma A en D, ¿qué resultado obtiene para XYZ?

Respuesta correcta: C) ABC

Explicación: El corrimiento de tres posiciones se aplica módulo 26 al final del alfabeto.

Fuente: 04 Cripto parte 1.pdf · págs. 11-13

008. Si un texto se cifró mediante ROT13 dos veces, ¿qué sucede?

Respuesta correcta: D) Se recupera el texto original

Explicación: ROT13 aplicado dos veces avanza 26 posiciones y restituye cada letra.

Fuente: 04 Cripto parte 1.pdf · págs. 11-13

009. ¿Cuál de los siguientes es un cifrado clásico de transposición?

Respuesta correcta: E) Escítala

Explicación: La escítala reordena posiciones de los caracteres en vez de sustituir su identidad.

Fuente: 04 Cripto parte 1.pdf · págs. 11-13

010. ¿Qué hace principalmente un cifrado clásico de sustitución?

Respuesta correcta: E) Reemplaza símbolos por otros según una regla

Explicación: Sustitución cambia los símbolos; transposición altera sus posiciones.

Fuente: 04 Cripto parte 1.pdf · págs. 11-13

011. ¿Por qué una clave secreta importa incluso si el algoritmo de cifrado es público?

Respuesta correcta: D) Porque la seguridad moderna debe depender de la clave y no del secreto del algoritmo

Explicación: La robustez criptográfica no debería basarse en ocultar el algoritmo.

Fuente: 04 Cripto parte 1.pdf · págs. 16-24, 30

012. ¿Qué relación mantienen las claves en un sistema de cifrado simétrico convencional?

Respuesta correcta: C) Se usa la misma clave secreta para cifrar y descifrar

Explicación: Un sistema simétrico necesita una clave secreta compartida por las partes.

Fuente: 04 Cripto parte 1.pdf · págs. 16-24, 30

013. En un sistema asimétrico, ¿cuál es la relación típica de las claves?

Respuesta correcta: B) Un par formado por clave pública y clave privada

Explicación: La criptografía asimétrica utiliza claves matemáticamente vinculadas con roles diferentes.

Fuente: 04 Cripto parte 1.pdf · págs. 16-24, 30

014. ¿Por qué la distribución de claves es una dificultad práctica de la criptografía simétrica?

Respuesta correcta: E) Emisor y receptor deben obtener la misma clave de forma segura

Explicación: La dificultad es intercambiar la clave sin que la conozcan terceros.

Fuente: 04 Cripto parte 1.pdf · págs. 16-24, 30

015. El mismo mensaje plano se cifra dos veces con idéntica clave y sin aleatoriedad. En ECB, ¿qué riesgo aparece?

Respuesta correcta: C) Los bloques iguales producen bloques cifrados iguales

Explicación: ECB cifra independientemente cada bloque y revela patrones repetidos.

Fuente: 04 Cripto parte 1.pdf · págs. 25-28

016. En CBC, ¿qué operación combina cada bloque plano con el encadenamiento previo antes del cifrado?

Respuesta correcta: E) XOR

Explicación: CBC realiza XOR con el bloque cifrado previo o con el IV inicial.

Fuente: 04 Cripto parte 1.pdf · págs. 25-28

017. ¿Por qué se utiliza un IV adecuado en el comienzo de CBC?

Respuesta correcta: E) Para que el primer bloque no dependa únicamente de texto plano y clave

Explicación: El vector de inicialización introduce variación inicial en el encadenamiento CBC.

Fuente: 04 Cripto parte 1.pdf · págs. 25-28

018. ¿Qué modalidad de cifrado se adapta a flujos de datos producidos continuamente?

Respuesta correcta: A) Cifrado de flujo

Explicación: Los cifrados de flujo procesan secuencias continuas sin esperar bloques grandes.

Fuente: 04 Cripto parte 1.pdf · págs. 25-29

019. ¿Qué desventaja de ECB se observa al cifrar imágenes con regiones repetitivas?

Respuesta correcta: C) Se conservan patrones visuales por igualdad de bloques

Explicación: ECB preserva relaciones entre bloques repetidos, lo que puede hacer reconocibles estructuras.

Fuente: 04 Cripto parte 1.pdf · págs. 25-29

020. Un bloque de 128 bits equivale exactamente a ¿cuántos bytes?

Respuesta correcta: B) 16

Explicación: 128 bits divididos entre 8 bits por byte son 16 bytes.

Fuente: 04 Cripto parte 1.pdf · págs. 25-29

021. ¿Qué propiedad espera normalmente de una función hash criptográfica?

Respuesta correcta: A) Salida de tamaño fijo para entradas de tamaño variable

Explicación: Un hash mapea entradas arbitrarias a resúmenes de longitud fija.

Fuente: 04 Cripto parte 1.pdf · págs. 17-20

022. ¿Qué es una colisión criptográfica?

Respuesta correcta: C) Dos entradas diferentes con el mismo hash

Explicación: La salida finita implica que pueden existir entradas distintas con igual digest.

Fuente: 04 Cripto parte 1.pdf · págs. 17-20

023. ¿Qué longitud tiene el resumen de MD5?

Respuesta correcta: C) 128 bits

Explicación: MD5 produce un digest de 128 bits.

Fuente: 04 Cripto parte 1.pdf · págs. 17-20

024. ¿Qué longitud tiene SHA-1?

Respuesta correcta: B) 160 bits

Explicación: SHA-1 produce 160 bits.

Fuente: 04 Cripto parte 1.pdf · págs. 17-20

025. ¿Cuántos dígitos hexadecimales tiene un hash SHA-256 completo?

Respuesta correcta: A) 64

Explicación: Cada dígito hexadecimal representa 4 bits; 256/4 = 64.

Fuente: 04 Cripto parte 1.pdf · págs. 17-20

026. ¿Por qué MD5 no es apropiado como hash resistente a colisiones en aplicaciones nuevas?

Respuesta correcta: C) Existen ataques prácticos que producen colisiones

Explicación: La resistencia a colisiones de MD5 ha sido comprometida.

Fuente: 04 Cripto parte 1.pdf · págs. 17-20

027. ¿Cuál es el principal riesgo de usar SHA-256 sin salt ni función de derivación para almacenar contraseñas?

Respuesta correcta: C) Facilita ataques de diccionario y comprobación masiva

Explicación: Las contraseñas requieren hashes lentos y salts únicos contra ataques offline.

Fuente: 04 Cripto parte 1.pdf · págs. 17-20

028. ¿Qué distingue a una función hash de un cifrado reversible?

Respuesta correcta: A) El hash no ofrece una operación de descifrado para recuperar arbitrariamente la entrada

Explicación: Los resúmenes se diseñan como funciones unidireccionales.

Fuente: 04 Cripto parte 1.pdf · págs. 17-20

029. En la verificación de integridad de un archivo descargado, ¿qué comparación se hace?

Respuesta correcta: B) Hash calculado del archivo frente al digest confiable esperado

Explicación: La coincidencia de un hash confiable puede evidenciar que el contenido no cambió.

Fuente: 04 Cripto parte 1.pdf · págs. 17-20

030. ¿Qué representa el ataque de colisión de MD5 mostrado con dos imágenes distintas?

Respuesta correcta: C) Archivos diferentes pueden tener igual digest MD5

Explicación: La colisión exhibe límites reales de MD5 como identificador resistente a adversarios.

Fuente: 04 Cripto parte 1.pdf · págs. 17-20

031. ¿Por qué el uso de hash en firmas digitales exige resistencia a colisiones?

Respuesta correcta: A) Para evitar sustituir un documento firmado por otro con el mismo digest

Explicación: Si dos mensajes comparten digest, podrían aprovechar una firma del digest de uno para otro.

Fuente: 04 Cripto parte 1.pdf · págs. 17-20

032. ¿Cuál es la desventaja operativa más destacada del cifrado simétrico al ampliar el número de participantes?

Respuesta correcta: E) Gestionar y distribuir secretos compartidos de forma segura

Explicación: El intercambio y la gestión de claves se dificultan al crecer los participantes.

Fuente: 04 Cripto parte 1.pdf · págs. 22-30

033. Si se cifra por bloques y el mensaje no ocupa un múltiplo del tamaño de bloque, ¿qué mecanismo puede requerirse en modos como CBC?

Respuesta correcta: D) Padding

Explicación: El relleno completa el último bloque según el esquema de padding usado.

Fuente: 04 Cripto parte 1.pdf · págs. 22-30

034. ¿Qué conclusión NO puede obtenerse únicamente porque dos archivos tengan distinto SHA-256?

Respuesta correcta: E) Que uno de los archivos es necesariamente malicioso

Explicación: Una diferencia de hashes no informa por sí sola sobre intención maliciosa.

Fuente: 04 Cripto parte 1.pdf · págs. 22-30

035. ¿Qué condición es necesaria para descifrar correctamente un mensaje con cifrado simétrico?

Respuesta correcta: A) Disponer de la clave apropiada y los parámetros del modo de operación

Explicación: El algoritmo requiere clave y, según el modo, IV, nonce y demás parámetros correctos.

Fuente: 04 Cripto parte 1.pdf · págs. 22-30

036. Un equipo quiere recuperar el texto original aplicando directamente una función SHA-256 al digest. ¿Cuál es el error conceptual?

Respuesta correcta: C) SHA-256 es una función hash y no ofrece una operación inversa de descifrado

Explicación: El material distingue hashing unidireccional de cifrado reversible; el digest no contiene una vía de descifrado.

Fuente: 04 Cripto parte 1.pdf · pág. 17

037. Dos usuarios obtienen exactamente el mismo digest al procesar idéntica secuencia de bytes con una misma función hash. ¿Qué propiedad explica el resultado?

Respuesta correcta: E) Determinismo de la función hash

Explicación: El material indica que para un mismo mensaje, la función hash devuelve el mismo resumen.

Fuente: 04 Cripto parte 1.pdf · pág. 17

038. En el ejemplo de los apuntes, «Ciberseguridad» y «CiberSeguridad» generan digest MD5 diferentes. ¿Qué factor cambió?

Respuesta correcta: E) El contenido de entrada, aunque solo cambió la capitalización de una letra

Explicación: Los bytes de entrada no son idénticos y los hashes reflejan esa diferencia.

Fuente: 04 Cripto parte 1.pdf · pág. 18

039. Para identificar si una imagen fue sustituida por otra distinta, un analista calcula MD5 y detecta una coincidencia. ¿Qué precaución exige el ejemplo ship.jpg/plane.jpg?

Respuesta correcta: E) La igualdad del MD5 no demuestra identidad de contenido, porque existen colisiones

Explicación: Los apuntes muestran dos imágenes diferentes con exactamente el mismo MD5.

Fuente: 04 Cripto parte 1.pdf · pág. 20

040. ¿Qué relación existe entre SHA-256 y SHA-512 según las familias SHA-2 enumeradas en clase?

Respuesta correcta: B) Ambos pertenecen a SHA-2 y producen digest de distinta longitud

Explicación: La diapositiva incluye SHA-224/256/384/512 dentro de SHA-2.

Fuente: 04 Cripto parte 1.pdf · pág. 18

041. Almacenar un hash rápido de contraseñas simples permite probar muchos candidatos en poco tiempo. ¿Qué problema del material explica este riesgo?

Respuesta correcta: D) La velocidad de cálculo favorece el ataque por fuerza bruta

Explicación: Los apuntes señalan que el cálculo rápido de hashes puede facilitar ataques de fuerza bruta.

Fuente: 04 Cripto parte 1.pdf · pág. 19

042. Una aplicación necesita comprobar si un archivo coincide con una versión conocida. ¿Cuál es el uso pertinente del digest?

Respuesta correcta: E) Comparar los hashes calculados sobre ambas versiones

Explicación: La comparación de digest puede identificar cambios en datos cuando se utiliza una función adecuada.

Fuente: 04 Cripto parte 1.pdf · pág. 17

043. Un programa cambia un único bit del mensaje antes de calcular el digest. ¿Qué comportamiento esperado se destaca en el apunte?

Respuesta correcta: A) Una alteración pequeña de entrada puede cambiar ampliamente el digest

Explicación: Los apuntes describen un cambio importante del resumen ante modificaciones pequeñas de entrada.

Fuente: 04 Cripto parte 1.pdf · pág. 17

044. En un esquema de firma digital se usa el resumen de un documento. ¿Por qué es relevante la resistencia a colisiones?

Respuesta correcta: E) Evita que sea fácil obtener dos documentos distintos con un mismo resumen

Explicación: Si se pueden construir documentos diferentes con igual digest, se compromete su identificación por hash.

Fuente: 04 Cripto parte 1.pdf · pág. 19

045. Se distribuye una clave secreta a seis participantes para que todos descifren mensajes. ¿Qué dificultad se intensifica?

Respuesta correcta: D) Proteger y administrar el secreto compartido entre varios usuarios

Explicación: El material resalta que compartir una misma clave en grupos no escala cómodamente.

Fuente: 04 Cripto parte 1.pdf · pág. 30

046. Una aplicación cifra un archivo con AES usando ECB y se distinguen formas repetidas de una imagen. ¿Qué decisión explica la filtración visual?

Respuesta correcta: A) Cifrar cada bloque independientemente con la misma clave

Explicación: ECB produce bloques cifrados iguales para bloques de texto claro iguales bajo la misma clave.

Fuente: 04 Cripto parte 1.pdf · pág. 26

047. En CBC, el primer bloque de texto claro no tiene un bloque cifrado anterior. ¿Qué dato interviene en el encadenamiento inicial?

Respuesta correcta: B) Un vector de inicialización (IV)

Explicación: La primera operación del modo CBC utiliza un IV en lugar de un bloque cifrado precedente.

Fuente: 04 Cripto parte 1.pdf · pág. 27

048. Un canal de audio produce datos en fragmentos muy pequeños y continuos. Según los apuntes, ¿qué técnica es especialmente apropiada?

Respuesta correcta: E) Cifrado de flujo con una secuencia cifrante

Explicación: El apunte presenta los cifrados de flujo para datos generados en tiempo real, incluso de un bit.

Fuente: 04 Cripto parte 1.pdf · pág. 29

049. Una implementación combina cada bit de datos con un bit de keystream. ¿Qué recurso describe el material para esa combinación?

Respuesta correcta: D) XOR entre datos y secuencia cifrante

Explicación: La diapositiva describe el cifrado de flujo mediante combinación con la secuencia pseudoaleatoria.

Fuente: 04 Cripto parte 1.pdf · pág. 29

050. Una empresa compara el uso de un algoritmo simétrico entre dos extremos con su uso en cientos de usuarios. ¿Qué limitación destaca el apunte?

Respuesta correcta: E) La necesidad de distribuir y administrar claves compartidas de forma segura

Explicación: La escalabilidad de la gestión de claves compartidas es una desventaja explícita.

Fuente: 04 Cripto parte 1.pdf · pág. 30

051. ¿Qué diferencia elemental separa sustitución clásica y transposición clásica?

Respuesta correcta: B) La sustitución cambia símbolos; la transposición altera su posición

Explicación: El esquema de cifrados clásicos distingue mecanismos de sustitución y de reordenamiento.

Fuente: 04 Cripto parte 1.pdf · pág. 11

052. ¿Cuál de los siguientes aparece en los apuntes como máquina usada en criptografía clásica durante la Segunda Guerra Mundial?

Respuesta correcta: C) Enigma

Explicación: La máquina Enigma figura entre los ejemplos de criptografía clásica.

Fuente: 04 Cripto parte 1.pdf · pág. 12

053. Un mensaje se convirtió con Base64 y un tercero conoce la codificación. ¿Qué puede hacer sin disponer de una clave secreta?

Respuesta correcta: A) Decodificar los datos representados en Base64

Explicación: Base64 es codificación, no un mecanismo de secreto basado en una clave.

Fuente: 04 Cripto parte 1.pdf · pág. 7

054. Una secuencia binaria de ASCII estándar requiere representar una letra. ¿Cuántos bits de información define esa codificación?

Respuesta correcta: B) Siete bits

Explicación: Los apuntes definen ASCII como una codificación de caracteres de 7 bits.

Fuente: 04 Cripto parte 1.pdf · pág. 8

055. Se usa el mismo algoritmo de cifrado simétrico y la misma clave para cifrar y luego descifrar. ¿Qué cambio de rol ocurre?

Respuesta correcta: D) El receptor aplica descifrado para recuperar el mensaje original

Explicación: El emisor cifra con una clave compartida y el receptor descifra con esa misma clave.

Fuente: 04 Cripto parte 1.pdf · pág. 22

056. En el cifrado César ROT3 con letras A-Z y desplazamiento hacia adelante, ¿cuál es el cifrado de «ATAQUE»?

Respuesta correcta: E) DWDTXH

Explicación: Cada letra de ATAQUE avanza tres posiciones en el alfabeto A-Z con retorno al principio.

Fuente: 04 Cripto parte 1.pdf · pág. 13

057. En el cifrado César ROT3 con letras A-Z y desplazamiento hacia adelante, ¿cuál es el cifrado de «SEGURIDAD»?

Respuesta correcta: E) VHJXULGDG

Explicación: Cada letra de SEGURIDAD avanza tres posiciones en el alfabeto A-Z con retorno al principio.

Fuente: 04 Cripto parte 1.pdf · pág. 13

058. En el cifrado César ROT3 con letras A-Z y desplazamiento hacia adelante, ¿cuál es el cifrado de «CLAVE»?

Respuesta correcta: B) FODYH

Explicación: Cada letra de CLAVE avanza tres posiciones en el alfabeto A-Z con retorno al principio.

Fuente: 04 Cripto parte 1.pdf · pág. 13

059. En el cifrado César ROT3 con letras A-Z y desplazamiento hacia adelante, ¿cuál es el cifrado de «DATOS»?

Respuesta correcta: D) GDWRV

Explicación: Cada letra de DATOS avanza tres posiciones en el alfabeto A-Z con retorno al principio.

Fuente: 04 Cripto parte 1.pdf · pág. 13

060. Un texto cifrado mediante César ROT3 hacia adelante es «FODYH». ¿Qué texto se recupera al descifrarlo?

Respuesta correcta: A) CLAVE

Explicación: Para invertir ROT3 se retrocede tres posiciones por letra; el texto recuperado es CLAVE.

Fuente: 04 Cripto parte 1.pdf · pág. 13

061. Un digest SHA-224 completo de 224 bits se expresa en hexadecimal sin prefijos. ¿Cuántos dígitos ocupa?

Respuesta correcta: A) 56 dígitos

Explicación: Cada dígito hexadecimal representa 4 bits: 224/4 = 56.

Fuente: 04 Cripto parte 1.pdf · pág. 18

062. Un digest SHA-384 completo de 384 bits se expresa en hexadecimal sin prefijos. ¿Cuántos dígitos ocupa?

Respuesta correcta: B) 96 dígitos

Explicación: Cada dígito hexadecimal representa 4 bits: 384/4 = 96.

Fuente: 04 Cripto parte 1.pdf · pág. 18

063. Un digest SHA-512 completo de 512 bits se expresa en hexadecimal sin prefijos. ¿Cuántos dígitos ocupa?

Respuesta correcta: B) 128 dígitos

Explicación: Cada dígito hexadecimal representa 4 bits: 512/4 = 128.

Fuente: 04 Cripto parte 1.pdf · pág. 18

064. Para un byte de texto claro 0x3C y un byte de keystream 0xA5, ¿qué byte resulta de combinarlos mediante XOR?

Respuesta correcta: E) 0x99

Explicación: La combinación bit a bit XOR de 0x3C con 0xA5 produce 0x99.

Fuente: 04 Cripto parte 1.pdf · pág. 29

065. Para un byte de texto claro 0x55 y un byte de keystream 0x0F, ¿qué byte resulta de combinarlos mediante XOR?

Respuesta correcta: C) 0x5A

Explicación: La combinación bit a bit XOR de 0x55 con 0x0F produce 0x5A.

Fuente: 04 Cripto parte 1.pdf · pág. 29

066. Para un byte de texto claro 0xC3 y un byte de keystream 0x3D, ¿qué byte resulta de combinarlos mediante XOR?

Respuesta correcta: B) 0xFE

Explicación: La combinación bit a bit XOR de 0xC3 con 0x3D produce 0xFE.

Fuente: 04 Cripto parte 1.pdf · pág. 29

CSIRT

Preguntas de opción múltiple · Una única respuesta correcta · Justificá tu elección.

067. Si un tercero lee una base de datos sin autorización, aunque no la altere, ¿qué propiedad se compromete directamente?

Respuesta correcta: C) Confidencialidad

Explicación: La confidencialidad limita la lectura de información a sujetos autorizados.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

068. Si alguien modifica el saldo de una cuenta sin permiso pero el servicio sigue disponible, ¿qué atributo CIA se viola?

Respuesta correcta: A) Integridad

Explicación: Una modificación no autorizada viola la integridad, incluso si el servicio responde.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

069. Un ataque DDoS impide consultar un sistema durante horas. ¿Qué atributo CIA afecta más directamente?

Respuesta correcta: B) Disponibilidad

Explicación: El servicio deja de estar accesible cuando los usuarios lo necesitan.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

070. ¿Cuál de los siguientes no integra la tríada CIA clásica?

Respuesta correcta: D) No repudio

Explicación: La tríada incluye confidencialidad, integridad y disponibilidad; no repudio es otra propiedad.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

071. ¿Qué propiedad busca impedir que el autor de una operación niegue después haberla realizado?

Respuesta correcta: E) No repudio

Explicación: El no repudio aporta evidencia atribuible de la realización de una acción.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

072. ¿Qué diferencia mejor una vulnerabilidad de una amenaza?

Respuesta correcta: E) La primera es una debilidad; la segunda, un agente o evento capaz de explotarla

Explicación: Una vulnerabilidad es una debilidad explotable y la amenaza puede aprovecharla.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

073. Un servidor expone por error un panel de administración sin autenticación. ¿Qué describe la ausencia de control?

Respuesta correcta: B) Una vulnerabilidad

Explicación: La configuración insegura es la debilidad, aunque aún no exista explotación observada.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

074. En una evaluación de riesgo, ¿qué efecto tiene que el mismo incidente potencial afecte datos críticos en vez de datos públicos?

Respuesta correcta: D) Aumenta el impacto potencial

Explicación: La criticidad de los activos modifica el impacto y, por lo tanto, el riesgo.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

075. ¿En qué escenario se identifica un incidente consumado y no solo una amenaza?

Respuesta correcta: A) Se confirma la extracción de archivos confidenciales

Explicación: El incidente supone la concreción de una amenaza con efectos adversos.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

076. ¿Qué motivación relacionan los apuntes principalmente con el hacktivismo?

Respuesta correcta: A) Ideología

Explicación: Los hacktivistas suelen actuar por causas ideológicas.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

077. ¿Qué actor se asocia habitualmente con el espionaje estratégico y sabotaje?

Respuesta correcta: B) Estado-nación

Explicación: Los actores estatales persiguen con frecuencia objetivos geopolíticos de espionaje y sabotaje.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

078. Una persona interna utiliza su acceso legítimo para robar información. ¿Cómo se clasifica el origen de esta amenaza?

Respuesta correcta: B) Interna maliciosa

Explicación: Se trata de una acción intencional de alguien de la organización.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

079. ¿Cuál es un ejemplo de ataque Man in the Middle?

Respuesta correcta: E) Interponer un actor que observa o altera comunicaciones entre extremos

Explicación: MitM consiste en interponerse en el canal de comunicación.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

080. ¿Cuál de estos ejemplos es de ingeniería social?

Respuesta correcta: C) Convencer a alguien de entregar su código de acceso en una página falsa

Explicación: La ingeniería social explota la interacción humana mediante engaño.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

081. Un atacante consigue que una aplicación consulte una URL interna que él le proporciona. ¿Qué categoría de fallo se investiga?

Respuesta correcta: B) SSRF

Explicación: SSRF permite forzar solicitudes desde el servidor a destinos seleccionados.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

082. Una consulta manipula la sentencia SQL construida por un servicio web. ¿Cuál es el riesgo principal?

Respuesta correcta: A) SQL Injection

Explicación: Una entrada no separada de la consulta puede cambiar su significado SQL.

Fuente: 03 Conceptos Básicos.pdf · págs. 2-8

083. ¿Cuál es la relación que ejemplifica SolarWinds 2020 según los apuntes?

Respuesta correcta: D) Compromiso de cadena de suministro

Explicación: SolarWinds ejemplifica la distribución de software contaminado por la cadena de suministro.

Fuente: 03 Conceptos Básicos.pdf · págs. 9-10

084. Log4Shell se menciona como una vulnerabilidad crítica asociada a ¿qué ecosistema?

Respuesta correcta: E) Una biblioteca Java

Explicación: Log4Shell afecta a Log4j, biblioteca del ecosistema Java.

Fuente: 03 Conceptos Básicos.pdf · págs. 9-10

085. Un leak de credenciales aumenta especialmente el riesgo de ¿qué ataque cuando se reutilizan contraseñas?

Respuesta correcta: C) Credential stuffing

Explicación: La reutilización permite probar credenciales expuestas en otros servicios.

Fuente: 03 Conceptos Básicos.pdf · págs. 11-13

086. ¿Para qué sirve consultar Have I Been Pwned en el contexto de los apuntes?

Respuesta correcta: E) Verificar si una dirección aparece en filtraciones registradas

Explicación: El servicio informa exposición conocida, no constituye una garantía absoluta.

Fuente: 03 Conceptos Básicos.pdf · págs. 11-13

087. ¿Qué principio evita depender exclusivamente de un firewall perimetral?

Respuesta correcta: A) Defensa en profundidad

Explicación: La defensa en profundidad dispone de varias capas independientes de protección.

Fuente: 03 Conceptos Básicos.pdf · págs. 18

088. Una organización tiene firewall, pero no segmentación ni controles de endpoint. ¿Qué carencia es más evidente?

Respuesta correcta: D) Falta de capas de seguridad internas

Explicación: Un firewall aislado no sustituye la segmentación ni la seguridad de los hosts.

Fuente: 03 Conceptos Básicos.pdf · págs. 18

089. ¿Qué control corresponde principalmente a la capa host en el esquema de defensa en profundidad?

Respuesta correcta: C) EDR

Explicación: EDR monitoriza actividades de los endpoints; las otras opciones son servicios o registros.

Fuente: 03 Conceptos Básicos.pdf · págs. 18

090. ¿Cuál es una amenaza humana no maliciosa?

Respuesta correcta: A) Un error de configuración por impericia

Explicación: Un fallo humano sin intención dañina es una amenaza no maliciosa.

Fuente: 03 Conceptos Básicos.pdf · págs. 5-7

091. Un incendio destruye equipos y copias locales. ¿Cómo se clasifica principalmente la amenaza?

Respuesta correcta: E) Natural

Explicación: Los incendios se incluyen entre las amenazas de origen natural.

Fuente: 03 Conceptos Básicos.pdf · págs. 5-7

092. ¿Qué propiedad está comprometida cuando un mensaje se atribuye falsamente a una identidad, aunque el texto no se haya cambiado?

Respuesta correcta: C) Autenticidad

Explicación: La autenticidad trata sobre la legitimidad de la identidad u origen alegados.

Fuente: 03 Conceptos Básicos.pdf · págs. 3-4

093. ¿Qué tarea cumplen principalmente los registros regionales de Internet (RIR)?

Respuesta correcta: D) Gestionar la asignación de recursos numéricos de Internet por región

Explicación: Los RIR administran asignación y registro de recursos IP y ASN en sus regiones.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 3-5

094. ¿Qué RIR administra principalmente los recursos de América Latina?

Respuesta correcta: A) LACNIC

Explicación: LACNIC cubre América Latina y parte del Caribe.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 3-5

095. Una organización de África busca el RIR de su región. ¿Cuál corresponde?

Respuesta correcta: D) AFRINIC

Explicación: AFRINIC brinda servicios de registro en África.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 3-5

096. ¿Cuál es el RIR asociado en general con Europa?

Respuesta correcta: B) RIPE NCC

Explicación: RIPE NCC tiene competencia en Europa y otras zonas adyacentes.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 3-5

097. ¿Qué entidad se asocia con la región Asia-Pacífico?

Respuesta correcta: B) APNIC

Explicación: APNIC administra recursos de numeración en la región Asia-Pacífico.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 3-5

098. ¿Por qué los RIR publican datos de contactos vinculados con recursos IP?

Respuesta correcta: E) Para permitir identificar responsables y canalizar consultas o incidentes

Explicación: La información de asignación permite contactar a administradores y responsables de abuso.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 6-8

099. ¿Cuál es una limitación importante del protocolo WHOIS clásico para automatizar consultas?

Respuesta correcta: B) Las respuestas no siguen un formato de datos uniforme

Explicación: El texto libre y las diferencias entre servidores dificultan analizarlo de forma automática.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 6-8

100. ¿Qué ventaja tiene RDAP frente a WHOIS en el material?

Respuesta correcta: A) Estructura de datos JSON apta para procesamiento automático

Explicación: RDAP dispone de una representación normalizada en JSON.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 6-8

101. Una respuesta WHOIS identifica owner, inetnum y abuse-c. ¿Cuál campo es más útil para enviar una denuncia técnica de abuso?

Respuesta correcta: B) abuse-c

Explicación: abuse-c identifica el contacto para reportes de incidentes o abuso.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 6-8

102. Si whois devuelve el bloque 190.15.128.0/20 para una IP concreta, ¿qué representa inetnum?

Respuesta correcta: A) La red o rango de direcciones asignado

Explicación: El campo inetnum describe el conjunto numérico asignado.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 6-8

103. En una consulta WHOIS, un registro ERX-NETBLOCK podría aparecer porque ¿qué ocurrió?

Respuesta correcta: C) El espacio IP fue asignado históricamente antes de los RIR actuales

Explicación: Los registros legacy pueden derivar a resultados genéricos en un RIR no responsable.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 9-11

104. ¿Cuál es una respuesta apropiada ante un resultado WHOIS histórico de un RIR incorrecto?

Respuesta correcta: B) Consultar el servidor WHOIS específico del RIR correspondiente

Explicación: La consulta directa al registro correcto resuelve casos históricos como el de UNLP.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 9-11

105. ¿Qué consigue la opción -h en «whois 163.10.5.66 -h whois.lacnic.net»?

Respuesta correcta: B) Seleccionar el servidor WHOIS al que se consulta

Explicación: La opción -h permite elegir explícitamente el host servidor WHOIS.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 9-11

106. En el ejemplo de los apuntes, ¿qué organización figura como titular del bloque 163.10.0.0/16?

Respuesta correcta: E) Universidad Nacional de La Plata

Explicación: La consulta específica de LACNIC para el bloque muestra a UNLP como owner.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 9-11

107. Una respuesta RDAP contiene «events» con registration y last changed. ¿Qué informan esos campos?

Respuesta correcta: C) Fechas de registro y de modificación

Explicación: Los eventos RDAP enumeran hitos del ciclo de vida del recurso.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 11-14

108. ¿Qué contiene habitualmente entities en un registro RDAP?

Respuesta correcta: C) Organizaciones y contactos asociados al recurso

Explicación: Las entidades RDAP modelan titulares y personas o roles de contacto.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 11-14

109. ¿Cuál de los siguientes datos es más pertinente para un CSIRT que investiga tráfico malicioso originado en una IP?

Respuesta correcta: E) Contacto de abuso del titular del bloque

Explicación: El contacto de abuso permite notificar a quienes gestionan la IP.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 11-14

110. ¿Con qué tipo de información trabaja principalmente un servicio RDAP IP?

Respuesta correcta: B) Asignación de direcciones y entidades responsables

Explicación: RDAP es un mecanismo de consulta de registro, no un monitor de tráfico.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 11-14

111. ¿Qué relación existe entre IANA y los RIR?

Respuesta correcta: D) IANA coordina espacios de numeración a nivel global y los RIR gestionan regiones

Explicación: La administración del espacio de numeración está organizada global y regionalmente.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 11-14

112. ¿Cómo se identifica principalmente un contacto técnico en el ejemplo WHOIS de UNLP?

Respuesta correcta: C) Mediante un identificador en el campo tech-c

Explicación: tech-c referencia el contacto encargado de asuntos técnicos del recurso.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 11-14

113. ¿Qué significa que DNS sea jerárquico y distribuido?

Respuesta correcta: B) Que sus zonas y datos se administran en distintos niveles y servidores

Explicación: DNS organiza nombres por zonas y delegaciones descentralizadas.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 14-15

114. ¿Cuál es el nivel superior de la jerarquía DNS?

Respuesta correcta: C) La zona raíz «.»

Explicación: La raíz inicia la jerarquía desde la que se delegan los TLD.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 14-15

115. ¿Cuál de estos nombres corresponde a un ccTLD?

Respuesta correcta: E) .ar

Explicación: .ar es un dominio de nivel superior de código de país.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 14-15

116. ¿Qué tipo de TLD se utiliza para infraestructura como la resolución inversa de direcciones?

Respuesta correcta: E) .arpa

Explicación: El dominio .arpa se emplea para funciones de infraestructura como reverse DNS.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 14-15

117. ¿Qué hace un registro PTR típico en DNS inverso?

Respuesta correcta: C) Asociar una dirección IP con un nombre de host

Explicación: Un registro PTR permite consultas de nombre asociadas a direcciones.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 14-15

118. ¿Cuál es la función de un Registry de TLD?

Respuesta correcta: B) Mantener la información de registro oficial del TLD

Explicación: El Registry mantiene la base oficial del TLD.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 16

119. ¿Qué papel desempeña un Registrar en el proceso de registro de dominios?

Respuesta correcta: D) Comercializar y tramitar registros para registrantes

Explicación: El Registrar presta el servicio de registrar dominios ante el Registry.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 16

120. ¿Quién es el Registrant en el registro de un dominio?

Respuesta correcta: C) La persona u organización titular solicitante

Explicación: El Registrant es quien registra y posee el dominio.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 16

121. Según los apuntes, ¿qué particularidad puede tener un Registry?

Respuesta correcta: A) Puede actuar también como Registrar

Explicación: Un actor puede ejercer ambos roles, como sucede en algunos TLD.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 16

122. ¿Qué función cumple NIC Argentina con respecto a .ar en el ejemplo de la materia?

Respuesta correcta: A) Registry y Registrar

Explicación: En el material se cita a NIC Argentina como Registry y Registrar de .ar.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 16

123. Una denuncia involucra una página phishing alojada bajo un dominio. ¿Qué datos se buscan en registros de dominios?

Respuesta correcta: C) Registrar, registrante y contactos disponibles

Explicación: La registración puede orientar notificaciones e investigaciones del dominio implicado.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 17-20

124. Si los datos privados de un registrante están ocultos, ¿qué actor puede requerirlos legalmente con orden judicial?

Respuesta correcta: D) Una agencia de aplicación de la ley competente

Explicación: El material diferencia el contacto público de los datos obtenibles por LEA mediante facultades legales.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 17-20

125. ¿Puede una consulta RDAP demostrar que el contenido actual de un dominio es legítimo?

Respuesta correcta: C) No; el registro no certifica la legitimidad del sitio

Explicación: RDAP informa datos de registro, no certifica seguridad del servicio.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 17-20

126. ¿Cuál es la relación útil entre DNS y la investigación de abuso en un CSIRT?

Respuesta correcta: E) Los nombres y las direcciones permiten vincular recursos con contactos responsables

Explicación: Las consultas DNS complementan la identificación de activos y sus responsables.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 17-20

127. ¿Cuál de las siguientes fuentes es la más directa para obtener el contacto abuse de un bloque IP público?

Respuesta correcta: D) RDAP o WHOIS del registro numérico

Explicación: Los registros de numeración mantienen datos de los responsables del bloque.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 17-20

128. ¿Cómo se consulta de forma automatizable un registro de numeración moderno?

Respuesta correcta: C) Usando una consulta RDAP y procesando su JSON

Explicación: RDAP tiene estructura y campos que pueden procesarse programáticamente.

Fuente: 05 CSIRT - Recursos de Internet.pdf · págs. 17-20

129. ¿Qué registro DNS localiza principalmente los servidores receptores de correo de un dominio?

Respuesta correcta: E) MX

Explicación: Los registros MX anuncian los servidores de correo para un dominio.

Fuente: 06 encabezados_smtp.pdf · págs. 2-3

130. Para «host -t mx info.unlp.edu.ar», aparecen prioridades 10, 20 y 30. ¿Cuál suele intentarse primero?

Respuesta correcta: D) El servidor con prioridad 10

Explicación: En MX, los números de preferencia menores se prefieren primero.

Fuente: 06 encabezados_smtp.pdf · págs. 2-3

131. ¿Cuál es el puerto TCP tradicional de transferencia de correo SMTP entre servidores?

Respuesta correcta: D) 25

Explicación: El intercambio SMTP entre MTA utiliza tradicionalmente TCP/25.

Fuente: 06 encabezados_smtp.pdf · págs. 2-3

132. En el flujo habitual de correo, ¿qué protocolo se utiliza para recuperar mensajes desde un buzón, en lugar de enviarlos entre servidores?

Respuesta correcta: E) IMAP

Explicación: IMAP permite consultar mensajes en un servidor de correo.

Fuente: 06 encabezados_smtp.pdf · págs. 2-3

133. ¿Qué parte de un correo SMTP define el destinatario efectivo usado en la entrega?

Respuesta correcta: C) El envelope con RCPT TO

Explicación: El sobre SMTP dirige el enrutamiento y la entrega real.

Fuente: 06 encabezados_smtp.pdf · págs. 4-5, 10

134. ¿Qué directiva de SMTP define el remitente del sobre?

Respuesta correcta: E) MAIL FROM

Explicación: MAIL FROM establece el origen del envelope, independiente del From visible.

Fuente: 06 encabezados_smtp.pdf · págs. 4-5, 10

135. ¿Cuál es la diferencia entre «MAIL FROM» y «From:»?

Respuesta correcta: E) El primero pertenece al sobre SMTP; el segundo es una cabecera visible

Explicación: El campo From es contenido informativo del mensaje, no la orden de enrutamiento SMTP.

Fuente: 06 encabezados_smtp.pdf · págs. 4-5, 10

136. ¿Qué documento define las cabeceras de mensajes de Internet citadas en la materia?

Respuesta correcta: C) RFC 5322

Explicación: RFC 5322 especifica la estructura de mensajes y encabezados de correo.

Fuente: 06 encabezados_smtp.pdf · págs. 6-8

137. ¿Qué header influye principalmente en la dirección utilizada cuando un usuario pulsa «Responder»?

Respuesta correcta: C) Reply-To:

Explicación: Reply-To puede determinar un destino de respuesta diferente al remitente visible.

Fuente: 06 encabezados_smtp.pdf · págs. 6-8

138. ¿Qué suele indicar el campo «Return-Path» en un mensaje entregado?

Respuesta correcta: B) La ruta de retorno asociada al remitente del envelope

Explicación: Return-Path refleja la dirección de retorno usada para fallos de entrega.

Fuente: 06 encabezados_smtp.pdf · págs. 6-8

139. ¿Por qué no debe atribuirse el origen real de un correo solamente con su «From:»?

Respuesta correcta: C) Porque ese campo puede ser declarado por el emisor y falsificado

Explicación: From: puede falsificarse con independencia de la traza SMTP.

Fuente: 06 encabezados_smtp.pdf · págs. 6-8

140. ¿Qué campo permite reconstruir los saltos entre servidores de correo?

Respuesta correcta: B) Received:

Explicación: Cada servidor receptor añade típicamente su propio Received.

Fuente: 06 encabezados_smtp.pdf · págs. 6-8

141. ¿Cómo se analizan normalmente varios encabezados Received para reconstruir la ruta?

Respuesta correcta: C) Desde los más antiguos abajo hacia los más recientes arriba

Explicación: Los nuevos Received se anteponen a los existentes y reflejan el recorrido inverso en el archivo.

Fuente: 06 encabezados_smtp.pdf · págs. 6-8

142. ¿Cuál puede ser una advertencia al analizar un Received más antiguo declarado por un remitente desconocido?

Respuesta correcta: A) Parte de la traza previa al servidor de confianza podría haberse falsificado

Explicación: La confianza de un Received depende de quién lo añadió, especialmente en tramos no confiables.

Fuente: 06 encabezados_smtp.pdf · págs. 6-8

143. ¿Cuál de estas direcciones pertenece al espacio privado RFC 1918?

Respuesta correcta: E) 10.12.4.7

Explicación: 10.0.0.0/8 es rango privado definido por RFC 1918.

Fuente: 06 encabezados_smtp.pdf · págs. 4-10

144. ¿Cuál de estas direcciones corresponde al bloque privado 172.16.0.0/12?

Respuesta correcta: D) 172.20.4.5

Explicación: El rango privado abarca 172.16.0.0 a 172.31.255.255.

Fuente: 06 encabezados_smtp.pdf · págs. 4-10

145. Una cabecera Received contiene «[192.168.50.4]». ¿Qué limitación tiene para identificar al originador por Internet?

Respuesta correcta: E) Es una IP privada y por sí sola no identifica una ubicación pública

Explicación: La dirección RFC 1918 no es enrutable públicamente y puede repetirse en múltiples redes.

Fuente: 06 encabezados_smtp.pdf · págs. 4-10

146. ¿Qué información temporal debe conservarse al analizar cabeceras SMTP?

Respuesta correcta: D) Fecha, hora y zona horaria

Explicación: Las zonas horarias permiten correlacionar correctamente eventos entre servidores.

Fuente: 06 encabezados_smtp.pdf · págs. 4-10

147. ¿Qué problema plantea que un mensaje tenga «MAIL FROM: facturas@empresa.com» y «From: soporte@otro.com»?

Respuesta correcta: E) Puede existir una discrepancia intencional entre remitente de sobre y remitente mostrado

Explicación: El protocolo permite independizar sobre y cabeceras, lo que puede explotarse en spoofing.

Fuente: 06 encabezados_smtp.pdf · págs. 4-10

148. ¿Qué propiedad tiene el cuerpo del mensaje con relación a las cabeceras?

Respuesta correcta: D) Aparece después del bloque de encabezados, separado por una línea vacía

Explicación: En el formato del mensaje, los encabezados terminan antes de una línea en blanco que inicia el cuerpo.

Fuente: 06 encabezados_smtp.pdf · págs. 4-10

149. Una cabecera dice «Received: from cliente.example [198.51.100.9] by mx.example». ¿Quién es el receptor declarado de ese salto?

Respuesta correcta: A) mx.example

Explicación: La estructura Received indica que mx.example recibió la conexión del origen indicado.

Fuente: 06 encabezados_smtp.pdf · págs. 8-14

150. ¿Qué elemento describe mejor el campo Message-ID?

Respuesta correcta: B) Un identificador del mensaje que ayuda a relacionarlo en registros

Explicación: Message-ID identifica el mensaje pero puede ser controlado por el software emisor.

Fuente: 06 encabezados_smtp.pdf · págs. 8-14

151. ¿Por qué un email aparentemente enviado por el jefe y con Reply-To externo es sospechoso?

Respuesta correcta: E) Una respuesta puede dirigirse a un buzón controlado por otro actor

Explicación: Un Reply-To ajeno al remitente esperado puede desviar respuestas y datos confidenciales.

Fuente: 06 encabezados_smtp.pdf · págs. 8-14

152. ¿Cuál de estas herramientas citadas facilita el examen de encabezados de email?

Respuesta correcta: D) Google Admin Toolbox Messageheader

Explicación: La herramienta Messageheader ayuda a analizar saltos y tiempos de mensajes.

Fuente: 06 encabezados_smtp.pdf · págs. 5-16

153. ¿Cuál es la principal limitación de depender exclusivamente de un parser automático de encabezados?

Respuesta correcta: A) Puede interpretar mal tramos falsificados o contextos particulares

Explicación: La lectura crítica de las cabeceras sigue siendo necesaria.

Fuente: 06 encabezados_smtp.pdf · págs. 5-16

154. Si un correo no puede entregarse, ¿qué dirección usa habitualmente el sistema para notificaciones de rebote?

Respuesta correcta: D) La del MAIL FROM del sobre

Explicación: Los mensajes de estado de entrega emplean la dirección de retorno del envelope.

Fuente: 06 encabezados_smtp.pdf · págs. 5-16

155. ¿Qué comando SMTP inicia la transferencia del contenido de encabezados y cuerpo después del sobre?

Respuesta correcta: D) DATA

Explicación: DATA inicia la etapa de contenido del mensaje, después de establecer remitente y destinatarios.

Fuente: 06 encabezados_smtp.pdf · págs. 11-12

156. En una sesión SMTP, ¿qué significa una respuesta numérica 250 tras RCPT TO?

Respuesta correcta: E) Aceptación de la orden solicitada

Explicación: 250 suele representar una respuesta positiva de acción completada.

Fuente: 06 encabezados_smtp.pdf · págs. 11-12

157. Una respuesta SMTP «354 End data with ...» indica ¿qué estado?

Respuesta correcta: D) El servidor está listo para recibir el cuerpo del mensaje

Explicación: 354 es una respuesta intermedia al comando DATA.

Fuente: 06 encabezados_smtp.pdf · págs. 11-12

158. ¿Por qué es importante no confundir «To:» con los destinatarios reales del envío SMTP?

Respuesta correcta: E) Los RCPT TO efectivos pueden no coincidir con la cabecera To visible

Explicación: Las cabeceras son informativas y los destinatarios del sobre determinan la entrega.

Fuente: 06 encabezados_smtp.pdf · págs. 11-12

159. ¿Qué describe con mayor precisión un servidor SMTP relay?

Respuesta correcta: A) Un servidor que recibe y retransmite un mensaje hacia otro servidor

Explicación: El relay intermedia el transporte entre emisores y receptores.

Fuente: 06 encabezados_smtp.pdf · págs. 11-12

160. En una traza con dos Received confiables en 16:32 y 16:48 de la misma zona horaria, ¿cuánto tiempo transcurrió aproximadamente?

Respuesta correcta: E) 16 minutos

Explicación: La diferencia entre 16:32 y 16:48 es de 16 minutos.

Fuente: 06 encabezados_smtp.pdf · págs. 8-17

161. Una investigación necesita ubicar al responsable de la IP pública del servidor emisor. ¿Qué combinación de fuentes conviene?

Respuesta correcta: D) Received confiable y WHOIS/RDAP de la IP

Explicación: La traza proporciona IP y el registro de numeración identifica responsables.

Fuente: 06 encabezados_smtp.pdf · págs. 8-17

162. ¿Qué afirmación sobre ESMTPS en un Received es la más precisa?

Respuesta correcta: A) Indica una transferencia SMTP con TLS en ese salto, no la legitimidad total del remitente

Explicación: TLS protege un canal SMTP específico, no autentica necesariamente el contenido de origen.

Fuente: 06 encabezados_smtp.pdf · págs. 8-17

163. Un encabezado contiene dos IP privadas y un host de salto público confiable. ¿Qué IP sirve mejor para contactar al proveedor de red en Internet?

Respuesta correcta: A) La dirección pública del salto relevante

Explicación: Los contactos de registro corresponden a recursos públicos asignados; las IP privadas requieren contexto interno.

Fuente: 06 encabezados_smtp.pdf · págs. 8-17

164. ¿Qué define mejor un incidente de seguridad desde el punto de vista de los apuntes?

Respuesta correcta: C) Un evento adverso que compromete la seguridad de información o sistemas

Explicación: El incidente aparece cuando se concreta una amenaza con consecuencias adversas.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 2-17

165. Un CSIRT recibe un reporte de phishing dirigido a usuarios de su universidad. ¿Por qué le resulta pertinente?

Respuesta correcta: C) Afecta directamente a su comunidad objetivo

Explicación: La pertinencia incluye incidentes que afectan a los usuarios de su comunidad.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 2-17

166. Un servidor propio envía ataques a un tercero. ¿Es pertinente para el CSIRT de su organización?

Respuesta correcta: E) Sí, porque la actividad dañina se origina en un recurso propio

Explicación: La comunidad comprende sus recursos aun si el destinatario de la agresión es externo.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 2-17

167. ¿Qué significa la sigla CSIRT?

Respuesta correcta: C) Computer Security Incident Response Team

Explicación: CSIRT designa un equipo de respuesta a incidentes de seguridad informática.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 2-17

168. ¿Qué identifica a un CERT frente a un CSIRT en el contenido de la materia?

Respuesta correcta: A) Son denominaciones relacionadas de equipos que gestionan incidentes

Explicación: Ambos nombres se usan para equipos de respuesta, con variantes institucionales.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 2-17

169. ¿Cuál es un posible origen de un reporte de incidente para un CSIRT?

Respuesta correcta: A) Un usuario, un tercero o una herramienta de monitoreo

Explicación: Los incidentes llegan por personas de dentro o fuera y por sistemas de detección.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 2-17

170. ¿Cuál es el primer criterio para decidir pertinencia de una denuncia?

Respuesta correcta: B) Vinculación del afectado o el origen con la comunidad del CSIRT

Explicación: La competencia se establece por comunidad afectada y recursos que originan incidentes.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 2-17

171. ¿Por qué es importante clasificar y priorizar incidentes?

Respuesta correcta: B) Para concentrar esfuerzos según criticidad e impacto

Explicación: La prioridad permite gestionar recursos limitados donde hay más riesgo e impacto.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 2-17

172. ¿Qué situación amerita normalmente mayor prioridad?

Respuesta correcta: B) Base de datos con información sensible expuesta públicamente

Explicación: La exposición de datos sensibles puede causar impacto elevado.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 2-17

173. Un incidente de malware en un equipo secundario evoluciona y comienza a atacar redes ajenas. ¿Qué variable puede elevar su prioridad?

Respuesta correcta: C) Impacto a terceros y reputación organizacional

Explicación: Los daños a terceros pueden aumentar la criticidad por riesgos externos y reputacionales.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 2-17

174. ¿Por qué el valor del activo afectado influye en la prioridad?

Respuesta correcta: B) Un sistema crítico puede amplificar el daño de un evento

Explicación: El impacto organizacional depende de la relevancia del recurso comprometido.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 2-17

175. ¿Qué tipo de amenaza representa un empleado que borra datos involuntariamente?

Respuesta correcta: C) Humana no maliciosa

Explicación: La impericia o error sin intención entra en amenazas humanas no maliciosas.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 2-17

176. ¿Cuál de estas opciones es un incidente de confidencialidad?

Respuesta correcta: D) Publicación no autorizada de una nómina privada

Explicación: La fuga de datos expone información a personas sin autorización.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 2-17

177. ¿Qué tarea corresponde a la fase de recepción?

Respuesta correcta: E) Registrar y reunir la información inicial de un reporte

Explicación: La recepción captura los hechos reportados para posterior evaluación.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 8-14

178. ¿Cuál es una consecuencia de clasificar por tipo sin evaluar el recurso afectado?

Respuesta correcta: E) Subestimar incidentes en activos de misión crítica

Explicación: La clasificación debe considerar tipo, activo e impacto.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 8-14

179. ¿Qué diferencia hay entre un alerta técnica y un incidente confirmado?

Respuesta correcta: B) La alerta requiere evaluación y puede no corresponder a un compromiso

Explicación: Una detección puede ser falsa positiva o un evento inocuo; hace falta validación.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 8-14

180. ¿Qué elemento debe incluir una notificación de incidente para facilitar investigación técnica?

Respuesta correcta: A) Registros relevantes con timestamps y zonas horarias

Explicación: Los tiempos, la zona horaria y la evidencia sustentan el análisis y la correlación.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 18-19

181. ¿Por qué se informa explícitamente la zona horaria de los logs?

Respuesta correcta: D) Para evitar correlaciones temporales equivocadas

Explicación: El mismo instante tiene horas distintas según la zona y el offset.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 18-19

182. Al notificar un abuso originado en un bloque ajeno, ¿qué contacto es prioritario?

Respuesta correcta: E) El contacto de abuso o seguridad asignado al recurso

Explicación: El contacto de abuse existe para canalizar incidentes del recurso.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 18-19

183. Un informe técnico ofrece una IP, fecha, puertos y mensajes de error. ¿Qué ventaja tiene?

Respuesta correcta: A) Permite contrastar el evento con registros del destinatario

Explicación: Los indicadores concretos permiten a responsables validar el evento.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 18-19

184. ¿Qué servicio de un CSIRT es fundamentalmente reactivo?

Respuesta correcta: B) Gestión y coordinación de incidentes reportados

Explicación: La atención de incidentes ya ocurridos es reactiva.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 22-26

185. ¿Qué servicio es principalmente proactivo?

Respuesta correcta: A) Auditorías y evaluaciones preventivas de seguridad

Explicación: Las auditorías buscan debilidades antes de que deriven en incidentes.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 22-26

186. ¿En qué grupo de servicios encaja típicamente la concientización de usuarios?

Respuesta correcta: B) Gestión de calidad de seguridad

Explicación: La concientización integra servicios de mejora de la seguridad.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 22-26

187. ¿Qué criterio se aplica al compartir datos sensibles de una investigación con otros equipos?

Respuesta correcta: A) Mínima difusión necesaria y canales de intercambio protegidos

Explicación: La confidencialidad requiere divulgar de forma controlada a destinatarios autorizados.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 22-26

188. ¿Qué beneficio tiene documentar la resolución de un incidente?

Respuesta correcta: C) Permite trazabilidad y aprendizaje para casos futuros

Explicación: Un registro de decisiones y evidencias facilita revisión y mejora.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 7-22

189. ¿Qué función desarrolla principalmente el CSIRT al coordinar varios administradores?

Respuesta correcta: B) Alinear acciones y comunicaciones necesarias para resolver el incidente

Explicación: La coordinación articula acciones entre responsables de recursos.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 7-22

190. ¿Cuál es un ejemplo de defacement?

Respuesta correcta: B) Sustitución no autorizada del contenido de una página web

Explicación: Defacement consiste en modificar sin autorización el contenido visible de un sitio.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 7-22

191. ¿Qué es una clasificación razonable para una filtración confirmada de información personal?

Respuesta correcta: B) Incidente de exposición o fuga de datos

Explicación: La información privada divulgada constituye una exposición de datos.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 7-22

192. ¿Por qué no corresponde priorizar solo por cantidad de reportes?

Respuesta correcta: A) Un evento poco reportado puede afectar un servicio crítico

Explicación: La severidad debe considerar naturaleza, activo e impacto, no solo volumen de avisos.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 7-22

193. Un usuario externo denuncia tráfico sospechoso desde una IP de la organización. ¿Qué corresponde hacer?

Respuesta correcta: E) Verificar titularidad y evidencias y evaluar pertinencia

Explicación: El origen propio puede justificar gestión aun cuando la denuncia sea externa.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 7-22

194. ¿Qué pasa si una amenaza natural interrumpe sistemas esenciales sin actor malicioso?

Respuesta correcta: D) Puede generar igualmente un incidente de seguridad que compromete disponibilidad

Explicación: Un evento adverso puede afectar la disponibilidad con independencia de intencionalidad.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 7-22

195. ¿Para qué sirve la comunicación con un responsable técnico de un recurso?

Respuesta correcta: C) Permitirle investigar y aplicar medidas sobre el activo

Explicación: El responsable debe recibir hechos accionables para corregir o contener el problema.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 7-22

196. ¿Qué práctica dificulta innecesariamente una notificación de incidente?

Respuesta correcta: D) Enviar logs sin indicar zona horaria ni contexto

Explicación: Sin contexto temporal y técnico, el destinatario no puede correlacionar la evidencia con facilidad.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 7-22

197. ¿Qué representa un servicio de continuidad del negocio dentro de un CSIRT?

Respuesta correcta: E) Planificación para mantener o recuperar funciones esenciales ante interrupciones

Explicación: La continuidad y recuperación ante desastres se consideran servicios de calidad de seguridad.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 7-22

198. ¿Qué significa «comunidad objetivo» de un CSIRT?

Respuesta correcta: D) Conjunto de usuarios, organizaciones y recursos a los que brinda respuesta

Explicación: El alcance del equipo determina a qué colectivos y recursos debe atender.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · págs. 7-22

199. Un reporte de ataque llega a un CSIRT, pero no afecta a su comunidad objetivo ni se originó en sus recursos. ¿Qué evaluación corresponde?

Respuesta correcta: A) No es pertinente para su ámbito de actuación directo

Explicación: La pertinencia se determina por afectación u origen en la comunidad objetivo.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · pág. 10

200. Un CSIRT encuentra dos incidentes simultáneos: spam aislado en una PC y una base de datos sensibles pública en Internet. ¿Cuál atiende primero según el ejemplo?

Respuesta correcta: D) La base de datos con información sensible expuesta

Explicación: Los apuntes asignan prioridad alta a una DB sensible expuesta y baja a spam aislado.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · pág. 15

201. Una organización sufre un incendio que daña servidores. ¿Cómo clasifica el CSIRT el origen de la amenaza?

Respuesta correcta: E) Natural

Explicación: Los incidentes pueden originarse en sucesos naturales, como incendios.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · pág. 5

202. En la investigación de un incidente, la hora del registro está escrita como «13:00» sin UTC ni zona. ¿Qué información falta para correlacionar eventos?

Respuesta correcta: C) La zona horaria asociada al timestamp

Explicación: La notificación debe incluir la zona horaria de los registros presentados.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · pág. 18

203. Una IP pública genera conexiones abusivas hacia una universidad. ¿Qué datos aportan WHOIS/RDAP para notificar correctamente?

Respuesta correcta: E) Entidad asignataria y contacto de abuso del bloque

Explicación: El registro público permite ubicar al responsable del bloque y los contactos pertinentes.

Fuente: 05 CSIRT - Recursos de Internet.pdf · pág. 7

204. Una consulta WHOIS retorna un bloque ERX histórico genérico. ¿Qué estrategia aparece en los apuntes?

Respuesta correcta: C) Repetir la consulta contra el WHOIS específico del RIR responsable

Explicación: El material ejemplifica consultas directas a whois.lacnic.net ante la respuesta ERX.

Fuente: 05 CSIRT - Recursos de Internet.pdf · pág. 11

205. En registros de dominio, ¿qué entidad figura como quien solicita y posee efectivamente el nombre?

Respuesta correcta: D) Registrant

Explicación: Registrant es el cliente titular de un dominio, distinto del registro y del registrador.

Fuente: 05 CSIRT - Recursos de Internet.pdf · pág. 16

206. Una consulta RDAP debe integrarse con un programa que extrae contactos automáticamente. ¿Qué característica lo facilita frente a WHOIS?

Respuesta correcta: E) La estructura de datos JSON

Explicación: RDAP entrega información estructurada, adecuada para procesamiento automático.

Fuente: 05 CSIRT - Recursos de Internet.pdf · pág. 6

207. El WHOIS de un dominio informa «Registrant Name: Redacted by Privacy». ¿Qué interpretación coincide con la clase?

Respuesta correcta: A) El registrador puede ocultar los datos personales públicos del registrante

Explicación: Los datos visibles pueden proteger la privacidad sin que eso implique ausencia de registro.

Fuente: 05 CSIRT - Recursos de Internet.pdf · pág. 18

208. Un mensaje de correo contiene «MAIL FROM: a@ejemplo» en su transacción y «From: b@ejemplo» en el encabezado. ¿Qué demuestra el caso?

Respuesta correcta: D) Envelope SMTP y encabezados informativos pueden ser diferentes

Explicación: Los apuntes muestran que los campos envelope son independientes del From visible.

Fuente: 06 encabezados_smtp.pdf · pág. 10

209. Si un servidor registra «250 2.1.5 Ok» luego de RCPT TO, ¿qué significa en el intercambio SMTP mostrado?

Respuesta correcta: C) Aceptó la indicación del destinatario en esa etapa

Explicación: La transacción SMTP utiliza respuestas de confirmación para los comandos del envelope.

Fuente: 06 encabezados_smtp.pdf · pág. 11

210. Durante el análisis de correo se observa una IP 192.168.1.40 en una traza Received. ¿Qué precaución corresponde?

Respuesta correcta: A) Tratarla como dirección privada, no como IP pública atribuible por RIR

Explicación: 192.168.0.0/16 pertenece al espacio privado RFC 1918.

Fuente: 06 encabezados_smtp.pdf · pág. 2

211. ¿Qué secuencia general permite analizar el camino de servidores de un mensaje a partir de encabezados Received?

Respuesta correcta: E) Seguir los saltos registrados y contrastar los equipos que añadieron las cabeceras

Explicación: Los Received recogen saltos de transferencia, cuya confiabilidad se contrasta con el punto de recepción.

Fuente: 06 encabezados_smtp.pdf · pág. 8

212. Una alerta reporta phishing desde un dominio, pero el registrante público está oculto. ¿Qué contacto continúa siendo especialmente útil?

Respuesta correcta: C) Contacto de abuso del registrador o proveedor responsable

Explicación: Los datos de registro permiten ubicar responsables de abuso incluso con privacidad del registrante.

Fuente: 05 CSIRT - Recursos de Internet.pdf · pág. 19

213. Si un equipo de respuesta distribuye evidencia sensible a otros CSIRTs, ¿qué protocolo de etiquetado limita la redistribución?

Respuesta correcta: E) Traffic Light Protocol (TLP)

Explicación: TLP se utiliza para acordar hasta dónde puede circular información sensible compartida.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · pág. 24

214. Una forensia debe enviarse de manera protegida entre dos integrantes del CSIRT a distancia. ¿Qué herramienta de los apuntes es adecuada?

Respuesta correcta: E) PGP para proteger la comunicación

Explicación: PGP aparece como alternativa criptográfica para intercambiar documentos sensibles.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · pág. 26

215. Una institución recibe un reporte de una computadora que pertenece a otra organización, pero el ataque se origina desde su propia red. ¿Debe examinarlo?

Respuesta correcta: A) Sí, porque los incidentes causados por sus recursos también son de su interés

Explicación: Los apuntes incorporan el daño a terceros originado en recursos propios dentro de la comunidad de atención.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · pág. 7

216. ¿Cuál de estas actividades pertenece a los servicios de gestión de calidad de seguridad de un CSIRT?

Respuesta correcta: E) Concientización y capacitación

Explicación: Las tareas de calidad de seguridad incluyen educación, consultoría y continuidad.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · pág. 22

217. ¿Cuál de estas actividades se presenta como servicio proactivo y no reactivo?

Respuesta correcta: E) Auditorías y evaluaciones de seguridad

Explicación: Auditar antes de que se concrete un incidente es un servicio proactivo.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · pág. 22

218. Se detecta un host que realiza ataques DoS a terceros desde un laboratorio. ¿Qué variable eleva la prioridad según el material?

Respuesta correcta: E) El impacto sobre terceros y la reputación de la organización

Explicación: La priorización debe considerar los daños a terceros originados desde recursos propios.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · pág. 16

219. Al recibir un aviso, ¿cuál es la razón operativa para determinar pertinencia antes de coordinar acciones?

Respuesta correcta: D) Evitar tratar como propio un caso ajeno a la comunidad objetivo

Explicación: La secuencia de gestión distingue recepción, pertinencia, priorización y coordinación.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · pág. 8

220. Una amenaza existe, pero todavía no hay evidencia de explotación ni evento adverso. ¿Cuál es la clasificación más prudente?

Respuesta correcta: C) Amenaza potencial, no necesariamente incidente consumado

Explicación: Un incidente se produce cuando se concreta una amenaza y afecta la seguridad.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · pág. 6

221. Un mensaje sospechoso se reenvía como texto plano perdiendo las cabeceras originales. ¿Qué evidencia falta para investigar bien el origen?

Respuesta correcta: D) La traza de Received y demás encabezados del mensaje original

Explicación: Los encabezados originales aportan información sobre los servidores y tiempos por los que pasó el correo.

Fuente: 06 encabezados_smtp.pdf · pág. 7

222. ¿Qué identifica la prioridad numérica menor en una respuesta MX como «10 mx1» y «30 mx2» del ejemplo del apunte?

Respuesta correcta: E) La preferencia del servidor MX con valor 10 frente al de valor 30

Explicación: El registro MX presenta prioridades y nombres de servidores del dominio.

Fuente: 06 encabezados_smtp.pdf · pág. 3

223. Una notificación de incidente incluye fecha, hora y registro técnico, pero omite a quién pertenece la IP. ¿Qué consulta ayuda a completar el destinatario?

Respuesta correcta: E) WHOIS o RDAP para localizar al titular del recurso y su contacto de abuso

Explicación: Los registros públicos relacionan bloques IP con titulares y contactos de incidentes.

Fuente: 05 CSIRT - Recursos de Internet.pdf · pág. 7

224. Dos CSIRTs intercambian datos de personas afectadas. ¿Qué criterio de tratamiento indica la guía de buenas prácticas?

Respuesta correcta: D) Limitar el acceso y circulación de la información según confidencialidad y TLP

Explicación: El material pide preservar confidencialidad y respetar las condiciones de intercambio de información.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · pág. 23

225. Una base de datos de denuncias reúne múltiples reportes, pero los responsables gestionan primero los más críticos. ¿Qué etapa del proceso están aplicando?

Respuesta correcta: C) Clasificación y priorización de incidentes

Explicación: El CSIRT prioriza según tipo, recurso afectado e impacto en tareas críticas.

Fuente: 07 CSIRT - Gestión de incidentes.pdf · pág. 13

226. Un correo contiene un campo Reply-To que no coincide con From. ¿Cuál es la implicación operativa más directa para investigar phishing?

Respuesta correcta: B) Las respuestas pueden dirigirse a otra dirección distinta del remitente mostrado

Explicación: El campo Reply-To determina hacia dónde se dirigen las respuestas y debe inspeccionarse.

Fuente: 06 encabezados_smtp.pdf · pág. 6

Malware

Preguntas de opción múltiple · Una única respuesta correcta · Justificá tu elección.

227. ¿Qué distingue al análisis estático del dinámico de malware?

Respuesta correcta: A) El estático inspecciona el artefacto sin ejecutarlo

Explicación: La inspección estática evita la ejecución y la dinámica observa comportamiento al correr.

Fuente: 08 Analisis_de_malware.pdf · págs. 1-7

228. ¿Cuál es una pregunta central en el análisis de un archivo sospechoso?

Respuesta correcta: E) Qué hace y cómo detectar otros sistemas afectados

Explicación: El análisis busca conducta, persistencia, artefactos e indicadores de compromiso.

Fuente: 08 Analisis_de_malware.pdf · págs. 1-7

229. ¿Qué IOC es apropiado para identificar una muestra exacta de malware?

Respuesta correcta: B) Hash criptográfico del archivo

Explicación: El hash del archivo permite comparar una muestra con otras conocidas.

Fuente: 08 Analisis_de_malware.pdf · págs. 1-7

230. ¿Por qué un hash no basta para detectar todas las variantes de una familia de malware?

Respuesta correcta: A) Un cambio de pocos bytes puede cambiar el digest

Explicación: Los hashes exactos no identifican variantes recompiladas o alteradas.

Fuente: 08 Analisis_de_malware.pdf · págs. 1-7

231. ¿Cuál de estos es un IOC de red plausible?

Respuesta correcta: D) Un dominio consultado repetidamente por la muestra

Explicación: Dominios, URLs, IP y puertos pueden señalar actividad maliciosa observada.

Fuente: 08 Analisis_de_malware.pdf · págs. 1-7

232. ¿Por qué es útil identificar archivos creados por el malware?

Respuesta correcta: C) Para reconocer otras infecciones y entender persistencia

Explicación: Los artefactos del filesystem permiten buscar efectos comunes en endpoints.

Fuente: 08 Analisis_de_malware.pdf · págs. 1-7

233. ¿Qué clase de software malicioso busca cifrar archivos y exigir un pago?

Respuesta correcta: B) Ransomware

Explicación: Ransomware secuestra acceso a información mediante cifrado o extorsión.

Fuente: 08 Analisis_de_malware.pdf · págs. 1-7

234. ¿Qué define mejor un RAT malicioso?

Respuesta correcta: D) Herramienta de acceso remoto que permite control no autorizado

Explicación: Los RAT habilitan acceso y operaciones a distancia sobre un equipo comprometido.

Fuente: 08 Analisis_de_malware.pdf · págs. 1-7

235. ¿Qué herramienta consulta varios motores antivirus y datos de una muestra?

Respuesta correcta: B) VirusTotal

Explicación: VirusTotal agrega resultados de diversos motores y metadatos de archivos.

Fuente: 08 Analisis_de_malware.pdf · págs. 8-12

236. Si VirusTotal arroja cero detecciones, ¿qué conclusión es válida?

Respuesta correcta: A) No hay evidencia por esos motores, pero no se descarta malware

Explicación: La detección depende de firmas y heurísticas; ausencia de alertas no prueba inocuidad.

Fuente: 08 Analisis_de_malware.pdf · págs. 8-12

237. ¿Qué precaución se debe considerar antes de subir un archivo privado a un servicio de análisis público?

Respuesta correcta: E) Puede exponer la muestra o sus contenidos sensibles a terceros

Explicación: Servicios de terceros pueden almacenar y compartir muestras, por lo que se evalúa sensibilidad.

Fuente: 08 Analisis_de_malware.pdf · págs. 8-12

238. ¿Cuál es una utilidad del comando strings en un binario?

Respuesta correcta: D) Extraer secuencias imprimibles potencialmente reveladoras

Explicación: strings puede mostrar mensajes, rutas, URLs y otros indicadores legibles.

Fuente: 08 Analisis_de_malware.pdf · págs. 13-16

239. ¿Por qué buscar strings no siempre revela una URL de comando y control?

Respuesta correcta: E) Podría estar cifrada, construida en ejecución u ofuscada

Explicación: Los IOC pueden ocultarse o crearse en tiempo de ejecución.

Fuente: 08 Analisis_de_malware.pdf · págs. 13-16

240. ¿Qué significa el concepto WideChar en el contexto de strings Windows explicado?

Respuesta correcta: D) Representación de caracteres mediante unidades de 2 bytes, típicamente UTF-16

Explicación: Muchas cadenas Win32 usan unidades de 16 bits, por lo que strings ASCII no siempre las muestra.

Fuente: 08 Analisis_de_malware.pdf · págs. 13-16

241. ¿Qué formato utilizan comúnmente los .exe y .dll de Windows?

Respuesta correcta: D) Portable Executable (PE)

Explicación: Los ejecutables y bibliotecas Windows utilizan el formato PE.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-18

242. ¿Qué sección PE contiene normalmente instrucciones de código?

Respuesta correcta: A) .text

Explicación: .text suele alojar el código ejecutable de un PE.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-18

243. ¿Qué sección PE contiene habitualmente recursos como iconos y menús?

Respuesta correcta: A) .rsrc

Explicación: .rsrc reúne recursos incorporados al ejecutable.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-18

244. ¿Para qué sirve examinar la tabla de imports de un PE sospechoso?

Respuesta correcta: C) Inferir capacidades a partir de DLL y funciones importadas

Explicación: Las APIs importadas indican posibles capacidades del programa.

Fuente: 08 Analisis_de_malware.pdf · págs. 19-20

245. Una muestra importa URLDownloadToFile. ¿Qué comportamiento resulta plausible?

Respuesta correcta: B) Descarga de contenido remoto a un archivo

Explicación: URLDownloadToFile se emplea para descargar datos a una ruta local.

Fuente: 08 Analisis_de_malware.pdf · págs. 19-20

246. Una muestra importa CreateService. ¿Qué hipótesis conviene investigar?

Respuesta correcta: B) Instalación o modificación de servicios de Windows

Explicación: CreateService puede instalar servicios, incluido un mecanismo de persistencia.

Fuente: 08 Analisis_de_malware.pdf · págs. 19-20

247. ¿Qué API puede cambiar protección de una región de memoria para volverla ejecutable?

Respuesta correcta: B) VirtualProtect

Explicación: VirtualProtect modifica permisos de páginas de memoria en Windows.

Fuente: 08 Analisis_de_malware.pdf · págs. 19-20

248. ¿Qué pareja de funciones puede facilitar resolver APIs dinámicamente?

Respuesta correcta: B) LoadLibrary y GetProcAddress

Explicación: LoadLibrary carga una DLL y GetProcAddress obtiene direcciones de funciones exportadas.

Fuente: 08 Analisis_de_malware.pdf · págs. 19-20

249. ¿Cuál es el papel de InternetOpen en las APIs Windows mencionadas?

Respuesta correcta: C) Inicializar una sesión de acceso a Internet

Explicación: InternetOpen inicializa el contexto de conexiones WinINet.

Fuente: 08 Analisis_de_malware.pdf · págs. 19-20

250. ¿Qué API de Windows del material puede abrir una URL?

Respuesta correcta: B) InternetOpenUrl

Explicación: InternetOpenUrl inicia una petición sobre una dirección especificada.

Fuente: 08 Analisis_de_malware.pdf · págs. 19-20

251. ¿Qué utilidad tiene Resource Hacker para el análisis de malware?

Respuesta correcta: D) Examinar o extraer recursos embebidos en archivos PE

Explicación: Permite visualizar iconos, cuadros de diálogo y recursos binarios.

Fuente: 08 Analisis_de_malware.pdf · págs. 21-26

252. ¿Qué herramienta integra diferentes verificaciones estáticas sobre ejecutables Windows?

Respuesta correcta: A) pestudio

Explicación: pestudio combina metadatos, imports, cadenas y análisis de PE.

Fuente: 08 Analisis_de_malware.pdf · págs. 21-26

253. ¿Por qué un empaquetador o packer puede dificultar el análisis estático?

Respuesta correcta: B) Oculta o comprime el código que se reconstruye en ejecución

Explicación: El unpacking en memoria dificulta inspeccionar el contenido real del archivo en disco.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-33

254. ¿Cuál de estos indicios sugiere empaquetamiento de un PE?

Respuesta correcta: C) Muy pocas cadenas legibles e imports reducidos a funciones de carga

Explicación: Los packed suelen exponer pocas APIs y cadenas porque el contenido está codificado.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-33

255. Si el tamaño virtual de una sección PE difiere notablemente del tamaño en disco, ¿qué conviene investigar?

Respuesta correcta: B) Posible empaquetado u organización inusual de secciones

Explicación: Diferencias raw/virtual size son pistas para analizar empaquetadores, no pruebas concluyentes.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-33

256. ¿Qué afirmación sobre packing es correcta?

Respuesta correcta: D) Puede existir en software legítimo y malicioso; es solo un indicio

Explicación: El empaquetamiento también se usa legítimamente; exige correlación con más evidencia.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-33

257. ¿Cuál es el riesgo de basar la clasificación solo en el nombre de una DLL importada?

Respuesta correcta: A) La presencia de una API no demuestra que se ejecute ni con qué intención

Explicación: Una tabla de imports revela capacidades potenciales, no el recorrido real de ejecución.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-33

258. ¿Qué indica la cabecera MZ al comienzo de un archivo PE habitual?

Respuesta correcta: B) Firma de compatibilidad del formato ejecutable DOS/PE

Explicación: MZ aparece al inicio de ejecutables PE mediante la cabecera DOS.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-33

259. Un PE tiene .text, .data y .rsrc. ¿Cuál corresponde a variables globales inicializadas típicamente?

Respuesta correcta: B) .data

Explicación: La sección .data conserva datos globales y estáticos inicializados.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-33

260. ¿Qué determina la sección .rdata de un PE según la presentación introductoria?

Respuesta correcta: E) Datos de solo lectura y metadatos como información de imports

Explicación: .rdata contiene datos que no se modifican habitualmente en ejecución.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-33

261. ¿Cuál es un enfoque útil cuando un antivirus no identifica una muestra sospechosa?

Respuesta correcta: E) Inspeccionar strings, imports y estructura PE

Explicación: Un análisis estático de estructura puede encontrar indicios más allá de detecciones antivirus.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-33

262. ¿Qué diferencia existe entre indicador de compromiso y prueba de autoría del malware?

Respuesta correcta: E) Un IOC ayuda a detectar actividad; no identifica por sí solo al autor

Explicación: IOC y atribución son problemas distintos: detectar artefactos no determina quién los creó.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-33

263. ¿Qué inferencia sería excesiva al hallar una URL embebida en un ejecutable?

Respuesta correcta: E) Afirmar que el programa ya contactó esa URL en una ejecución concreta

Explicación: Encontrar una cadena no demuestra que una rama se haya ejecutado.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-33

264. ¿Por qué es útil identificar varias muestras con hashes diferentes pero conductas semejantes?

Respuesta correcta: A) Puede revelar variantes de una misma familia a pesar del cambio de bytes

Explicación: Las variantes suelen compartir indicadores conductuales aunque sus hashes difieran.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-33

265. ¿Cuál es una consecuencia práctica de buscar únicamente strings ASCII en malware de Windows?

Respuesta correcta: E) Omitir cadenas Unicode de 16 bits

Explicación: Hay binarios que guardan texto en UTF-16 y requieren extracción compatible.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-33

266. ¿Qué ventaja tiene combinar análisis de imports y strings?

Respuesta correcta: B) Cruzar capacidades potenciales con indicadores y rutas observables

Explicación: Varias fuentes estáticas aportan indicios complementarios para plantear hipótesis.

Fuente: 08 Analisis_de_malware.pdf · págs. 17-33

267. ¿Cuál es la finalidad principal del análisis dinámico de una muestra sospechosa?

Respuesta correcta: C) Observar cambios y comportamiento al ejecutarla bajo control

Explicación: El análisis dinámico revela efectos en procesos, archivos, registro y red.

Fuente: 08 Analisis_de_malware.pdf · págs. 34-40

268. ¿Por qué una única ejecución de malware no permite descartar capacidades adicionales?

Respuesta correcta: C) Pueden existir caminos de ejecución o disparadores no activados

Explicación: Las condiciones de entorno, parámetros y ramas pueden cambiar la conducta observable.

Fuente: 08 Analisis_de_malware.pdf · págs. 34-40

269. ¿Qué riesgo existe al ejecutar una muestra en una red corporativa real?

Respuesta correcta: A) Propagación o compromiso de otros equipos

Explicación: El laboratorio no debe exponer sistemas ajenos ni redes de producción.

Fuente: 08 Analisis_de_malware.pdf · págs. 34-40

270. ¿Qué entorno proponen los apuntes para restaurar el estado luego de pruebas?

Respuesta correcta: A) Máquina virtual con snapshots

Explicación: Las snapshots permiten volver a una situación anterior conocida del laboratorio.

Fuente: 08 Analisis_de_malware.pdf · págs. 34-40

271. ¿Qué riesgo introduce compartir carpetas del host con la VM infectada?

Respuesta correcta: A) Ofrece al malware acceso a archivos fuera del entorno aislado

Explicación: Las carpetas montadas amplían la superficie que el malware podría modificar.

Fuente: 08 Analisis_de_malware.pdf · págs. 34-40

272. ¿Por qué se recomienda registrar una línea de base antes de ejecutar la muestra?

Respuesta correcta: C) Para comparar el sistema limpio con su estado posterior

Explicación: Una línea de base revela archivos, claves y procesos creados o modificados.

Fuente: 08 Analisis_de_malware.pdf · págs. 34-40

273. ¿Qué problema aparece si la muestra ya se ejecutó varias veces sin restaurar snapshot?

Respuesta correcta: B) Algunos cambios iniciales pueden pasar inadvertidos en posteriores comparaciones

Explicación: Artefactos persistentes creados una vez no reaparecen como modificaciones nuevas.

Fuente: 08 Analisis_de_malware.pdf · págs. 34-40

274. ¿Por qué puede ser necesario probar malware con permisos administrativos en el laboratorio?

Respuesta correcta: B) Ciertas acciones requieren privilegios y podrían no manifestarse sin ellos

Explicación: Las operaciones privilegiadas como instalar servicios pueden requerir elevación.

Fuente: 08 Analisis_de_malware.pdf · págs. 34-40

275. ¿Cuál es una clave de usuario importante para estudiar persistencia de inicio automático?

Respuesta correcta: A) HKCU\Software\Microsoft\Windows\CurrentVersion\Run

Explicación: La clave Run del usuario actual puede iniciar comandos en el inicio de sesión.

Fuente: 08 Analisis_de_malware.pdf · págs. 41-47

276. ¿Qué representa HKCU en el Registro de Windows?

Respuesta correcta: E) HKEY_CURRENT_USER

Explicación: HKCU identifica configuraciones del perfil de usuario actual.

Fuente: 08 Analisis_de_malware.pdf · págs. 41-47

277. ¿Qué representa HKLM?

Respuesta correcta: D) HKEY_LOCAL_MACHINE

Explicación: HKLM almacena configuraciones a nivel de equipo.

Fuente: 08 Analisis_de_malware.pdf · págs. 41-47

278. ¿Por qué crear una entrada de Run en HKCU puede ser atractivo para malware sin elevación?

Respuesta correcta: A) Muchas claves de ese perfil son escribibles por el propio usuario

Explicación: Un usuario puede modificar muchas de sus propias configuraciones de inicio.

Fuente: 08 Analisis_de_malware.pdf · págs. 41-47

279. ¿Qué ruta del Registro contiene definiciones de servicios de Windows según los apuntes?

Respuesta correcta: A) HKLM\SYSTEM\CurrentControlSet\Services

Explicación: Los servicios se administran bajo HKLM\SYSTEM\CurrentControlSet\Services.

Fuente: 08 Analisis_de_malware.pdf · págs. 41-47

280. Una muestra instala un servicio para que se inicie al arrancar. ¿Qué categoría de comportamiento evidencia?

Respuesta correcta: B) Persistencia

Explicación: El servicio puede permitir que el código se reinicie sin acción manual posterior.

Fuente: 08 Analisis_de_malware.pdf · págs. 41-47

281. ¿Qué herramienta sirve para comparar dos estados del registro Windows?

Respuesta correcta: E) Regshot

Explicación: Regshot compara snapshots del registro antes y después de una ejecución.

Fuente: 08 Analisis_de_malware.pdf · págs. 49-55

282. ¿Qué utilidad tiene Autoruns en el estudio de malware Windows?

Respuesta correcta: B) Inspeccionar ubicaciones configuradas para inicio automático

Explicación: Autoruns enumera mecanismos comunes de autoejecución y persistencia.

Fuente: 08 Analisis_de_malware.pdf · págs. 49-55

283. ¿Qué herramienta de Sysinternals rastrea operaciones de procesos sobre registro, archivos y otros recursos?

Respuesta correcta: B) Process Monitor (Procmon)

Explicación: Procmon registra eventos del sistema por proceso y permite aplicar filtros.

Fuente: 08 Analisis_de_malware.pdf · págs. 49-55

284. ¿Por qué se aplican filtros en Procmon al analizar una muestra?

Respuesta correcta: E) Para separar eventos relevantes del enorme volumen de actividad del sistema

Explicación: El filtrado por proceso y operación ayuda a identificar sus efectos.

Fuente: 08 Analisis_de_malware.pdf · págs. 49-55

285. ¿Cuál es una evidencia clara de modificación del filesystem tras ejecutar un binario?

Respuesta correcta: C) Creación de un archivo que no existía en la línea de base

Explicación: Una comparación de antes y después identifica artefactos creados o modificados.

Fuente: 08 Analisis_de_malware.pdf · págs. 48-57

286. ¿Qué pareja de herramientas permite capturar tráfico producido durante el análisis?

Respuesta correcta: E) Wireshark y tcpdump

Explicación: Wireshark y tcpdump capturan paquetes para estudiar conexiones y protocolos.

Fuente: 08 Analisis_de_malware.pdf · págs. 48-57

287. ¿Qué herramienta citada simula varios servicios de Internet en un laboratorio Windows?

Respuesta correcta: D) FakeNet

Explicación: FakeNet permite emular respuestas de servicios de red para observar conexiones del malware.

Fuente: 08 Analisis_de_malware.pdf · págs. 48-57

288. ¿Qué tipo de servicio intenta simular específicamente FakeDNS?

Respuesta correcta: A) Resolución de nombres de dominio

Explicación: FakeDNS responde consultas DNS simuladas en un laboratorio.

Fuente: 08 Analisis_de_malware.pdf · págs. 48-57

289. ¿Cuál es el objetivo de simular servicios de red en un laboratorio de malware?

Respuesta correcta: E) Observar intentos de comunicación sin conectar a destinos reales

Explicación: Las simulaciones permiten registrar y controlar tráfico sin depender de servicios externos.

Fuente: 08 Analisis_de_malware.pdf · págs. 48-57

290. ¿Qué herramienta ayuda a inspeccionar procesos, árboles y handles en ejecución?

Respuesta correcta: C) Process Explorer

Explicación: Process Explorer proporciona información detallada de procesos activos.

Fuente: 08 Analisis_de_malware.pdf · págs. 48-57

291. ¿En qué se diferencia observar una URL en strings y una conexión efectivamente capturada?

Respuesta correcta: A) La segunda evidencia una acción de red durante una ejecución

Explicación: La traza de red prueba un intento o intercambio observado en ejecución.

Fuente: 08 Analisis_de_malware.pdf · págs. 48-57

292. Una ejecución genera una entrada Run en HKCU y una conexión TCP inesperada. ¿Qué dos capacidades sugiere?

Respuesta correcta: E) Persistencia y comunicación de red

Explicación: La entrada de inicio automático y el flujo TCP son evidencias de comportamientos diferentes.

Fuente: 08 Analisis_de_malware.pdf · págs. 48-57

293. ¿Qué capacidad presenta un downloader malicioso?

Respuesta correcta: A) Obtener y guardar componentes adicionales desde una fuente externa

Explicación: Los downloaders traen nuevas cargas o recursos desde Internet.

Fuente: 08 Analisis_de_malware.pdf · págs. 1-4

294. ¿Cómo se denomina el malware que registra pulsaciones del teclado sin autorización?

Respuesta correcta: D) Keylogger

Explicación: Los keyloggers capturan eventos de teclado y pueden filtrar credenciales.

Fuente: 08 Analisis_de_malware.pdf · págs. 1-4

295. ¿Qué categoría de malware busca ocultar su presencia y manipular la visibilidad del sistema?

Respuesta correcta: E) Rootkit

Explicación: Los rootkits intentan ocultar componentes y mantener un acceso privilegiado.

Fuente: 08 Analisis_de_malware.pdf · págs. 1-4

296. ¿Qué comportamiento es característico de un gusano informático?

Respuesta correcta: C) Propagarse autónomamente entre equipos

Explicación: Los gusanos tienen capacidad de autopropagación entre sistemas.

Fuente: 08 Analisis_de_malware.pdf · págs. 1-4

297. ¿Qué diferencia principalmente un troyano de un gusano?

Respuesta correcta: E) El troyano se presenta como algo útil, mientras que el gusano destaca por autopropagación

Explicación: Los troyanos engañan sobre su finalidad y los gusanos se propagan automáticamente.

Fuente: 08 Analisis_de_malware.pdf · págs. 1-4

298. ¿Qué característica define una botnet maliciosa?

Respuesta correcta: D) Conjunto de dispositivos comprometidos controlables coordinadamente

Explicación: Las botnets coordinan máquinas comprometidas para acciones como spam o DDoS.

Fuente: 08 Analisis_de_malware.pdf · págs. 1-4

299. ¿Por qué no conviene ejecutar malware directamente en el equipo de trabajo del analista?

Respuesta correcta: D) Puede comprometer datos, credenciales y redes accesibles

Explicación: Un host de uso normal expone información y recursos reales a la muestra.

Fuente: 08 Analisis_de_malware.pdf · págs. 37-40

300. ¿Qué permite un snapshot de VM durante un experimento repetible?

Respuesta correcta: D) Volver a un estado anterior antes de realizar otra prueba

Explicación: Las snapshots ayudan a reproducir condiciones iniciales del entorno.

Fuente: 08 Analisis_de_malware.pdf · págs. 37-40

301. En un reporte se confirman cambios en el registro y conexiones salientes de un ejecutable sospechoso. ¿Qué método obtuvo probablemente esta evidencia?

Respuesta correcta: E) Análisis dinámico de comportamiento

Explicación: Los cambios efectivamente observados durante ejecución son propios del análisis dinámico.

Fuente: 08 Analisis_de_malware.pdf · pág. 35

302. Un archivo no genera detecciones antivirus, pero importa APIs sospechosas. ¿Cuál es la conclusión analítica mejor respaldada?

Respuesta correcta: C) Conviene seguir investigando; la ausencia de detecciones no prueba inocuidad

Explicación: El análisis estático básico combina múltiples fuentes en lugar de depender de un solo resultado.

Fuente: 08 Analisis_de_malware.pdf · pág. 8

303. Un analista busca una URL en un PE y el comando strings estándar no encuentra nada. ¿Qué alternativa sugiere el apunte para cadenas Windows?

Respuesta correcta: E) Inspeccionar también cadenas WideChar/Unicode de dos bytes por carácter

Explicación: Las cadenas Windows pueden estar almacenadas como wide strings, no solo ASCII.

Fuente: 08 Analisis_de_malware.pdf · pág. 16

304. Un PE importa VirtualProtect y luego ejecuta bytes cargados en memoria. ¿Qué capacidad respalda la API importada?

Respuesta correcta: E) Modificar permisos de protección de una región de memoria

Explicación: VirtualProtect cambia permisos, potencialmente habilitando ejecución.

Fuente: 08 Analisis_de_malware.pdf · pág. 20

305. ¿Cuál de estas funciones es adecuada para resolver la dirección de una función en una DLL cargada dinámicamente?

Respuesta correcta: A) GetProcAddress

Explicación: GetProcAddress obtiene direcciones de funciones exportadas para uso dinámico.

Fuente: 08 Analisis_de_malware.pdf · pág. 20

306. Una muestra importa LoadLibrary y GetProcAddress pero pocas APIs más. ¿Qué hipótesis conviene evaluar?

Respuesta correcta: C) Que resuelva APIs dinámicamente y oculte capacidades de la tabla de imports

Explicación: Pocas importaciones con esas APIs son un indicio frecuente de empaquetamiento u ocultación.

Fuente: 08 Analisis_de_malware.pdf · pág. 29

307. ¿Cuál es la sección del formato PE que normalmente corresponde a iconos, menús y otros recursos incrustados?

Respuesta correcta: B) .rsrc

Explicación: El material relaciona .rsrc con recursos como iconos, menús y strings.

Fuente: 08 Analisis_de_malware.pdf · pág. 18

308. Un analista quiere explorar y extraer elementos incrustados en la sección de recursos de un PE. ¿Qué herramienta se menciona?

Respuesta correcta: A) Resource Hacker

Explicación: Resource Hacker permite inspeccionar recursos y obtener una vista previa.

Fuente: 08 Analisis_de_malware.pdf · pág. 21

309. En una muestra empaquetada, la mayor parte del contenido se descomprime al ejecutarse. ¿Qué inferencia es consistente con el apunte?

Respuesta correcta: C) El análisis estático del archivo en disco puede ocultar cadenas y código útil

Explicación: Los packers hacen más difícil observar el contenido por análisis estático.

Fuente: 08 Analisis_de_malware.pdf · pág. 27

310. Un archivo presenta pocos strings y solo imports de carga dinámica. ¿Qué decisión es más razonable?

Respuesta correcta: C) Investigar si está empaquetado u ofuscado

Explicación: Se trata de indicios enumerados para detectar packing.

Fuente: 08 Analisis_de_malware.pdf · pág. 29

311. ¿Qué aportan los imports del PE sin necesidad de ejecutar el programa?

Respuesta correcta: B) Pistas sobre librerías y posibles capacidades usadas por el binario

Explicación: Las funciones enlazadas permiten formular hipótesis sobre capacidades del malware.

Fuente: 08 Analisis_de_malware.pdf · pág. 19

312. Una muestra importa URLDownloadToFile pero no se observaron conexiones. ¿Qué afirmación es la más prudente?

Respuesta correcta: A) Podría descargar un archivo; falta evidencia de que lo haya hecho en esta ejecución

Explicación: Una API importada sugiere comportamiento potencial; la observación lo confirma o no.

Fuente: 08 Analisis_de_malware.pdf · pág. 19

313. Un ejecutable importa InternetOpen. ¿Qué parámetro de comunicaciones se destaca en los apuntes?

Respuesta correcta: C) User-Agent

Explicación: InternetOpen inicializa comunicaciones de Internet y recibe un User-Agent.

Fuente: 08 Analisis_de_malware.pdf · pág. 20

314. Un programa sospechoso importa CreateService. ¿Qué área de Windows conviene revisar inmediatamente en el laboratorio?

Respuesta correcta: C) Definiciones de servicios y mecanismos de arranque

Explicación: CreateService puede utilizarse para configurar servicios y persistencia.

Fuente: 08 Analisis_de_malware.pdf · pág. 20

315. ¿Qué rasgo del proceso de análisis explica que una ejecución sin argumentos no muestre conducta maliciosa, aunque exista?

Respuesta correcta: A) Pueden faltar parámetros que habilitan otras rutas de ejecución

Explicación: El material advierte que una ejecución no recorre todos los caminos.

Fuente: 08 Analisis_de_malware.pdf · pág. 36

316. Una muestra actúa solamente después de verificar una fecha o condición particular. ¿Qué limitación del análisis dinámico básico aparece?

Respuesta correcta: B) Puede no observarse el comportamiento al ejecutar solo una vez

Explicación: No se puede asegurar cobertura de todas las rutas de ejecución.

Fuente: 08 Analisis_de_malware.pdf · pág. 36

317. Un entorno de prueba de malware está conectado a la red de producción. ¿Cuál es el problema más grave señalado por el material?

Respuesta correcta: C) La muestra puede afectar otros equipos de la organización

Explicación: Las muestras pueden propagarse o conectarse a terceros; la red de producción debe aislarse.

Fuente: 08 Analisis_de_malware.pdf · pág. 37

318. Una VM maliciosa tiene una carpeta compartida de lectura/escritura con el host. ¿Qué riesgo agrega?

Respuesta correcta: A) Posibilidad de afectar archivos del host por el vínculo compartido

Explicación: Las carpetas compartidas y dispositivos conectados al host amplían el riesgo.

Fuente: 08 Analisis_de_malware.pdf · pág. 38

319. Durante un laboratorio se crean entradas de registro en la primera ejecución. ¿Qué se pierde si se vuelve a ejecutar sin restaurar un estado limpio?

Respuesta correcta: E) La posibilidad de observar nuevamente esas creaciones como diferencias nuevas

Explicación: Se recomienda restaurar snapshots; cambios previos pueden no reaparecer en mediciones posteriores.

Fuente: 08 Analisis_de_malware.pdf · pág. 40

320. El analista quiere maximizar la observación de acciones que requieren elevación en un entorno seguro. ¿Qué decisión contemplan los apuntes?

Respuesta correcta: D) Ejecutar la muestra con permisos administrativos dentro del laboratorio aislado

Explicación: El material contempla permisos de administrador en un ambiente controlado para observar capacidades.

Fuente: 08 Analisis_de_malware.pdf · pág. 40

321. ¿Cuál de estas ubicaciones permite configurar inicio en sesión del usuario sin requerir privilegios administrativos para escribir HKCU?

Respuesta correcta: E) HKCU\Software\Microsoft\Windows\CurrentVersion\Run

Explicación: Las Run keys bajo HKCU admiten entradas de inicio al autenticarse el usuario.

Fuente: 08 Analisis_de_malware.pdf · pág. 43

322. Se observa una nueva clave en HKLM\System\CurrentControlSet\Services. ¿Qué comportamiento amerita verificar?

Respuesta correcta: A) Creación o modificación de un servicio de Windows

Explicación: Los servicios se definen en esa rama del registro.

Fuente: 08 Analisis_de_malware.pdf · pág. 46

323. Un usuario reinicia su equipo y reaparece un programa sospechoso almacenado en una carpeta poco visible. ¿Qué modificación explicaría esto según las diapositivas?

Respuesta correcta: D) Un valor en HKCU\...\CurrentVersion\Run que apunta al binario

Explicación: Un valor Run puede lanzar nuevamente la muestra tras el inicio de sesión.

Fuente: 08 Analisis_de_malware.pdf · pág. 44

324. Se necesita comparar de manera sistemática entradas de registro antes y después de ejecutar una muestra. ¿Qué herramienta se elige?

Respuesta correcta: A) Regshot

Explicación: Regshot registra y compara el estado de elementos de la registry.

Fuente: 08 Analisis_de_malware.pdf · pág. 49

325. Se sospecha persistencia en varias ubicaciones de inicio de Windows. ¿Qué herramienta de la práctica permite inspeccionarlas?

Respuesta correcta: D) Autoruns

Explicación: Autoruns facilita revisar mecanismos comunes de autoejecución.

Fuente: 08 Analisis_de_malware.pdf · pág. 49

326. En Procmon aparecen miles de eventos de diferentes procesos. ¿Qué medida metodológica facilita reconocer acciones de la muestra?

Respuesta correcta: B) Filtrar por proceso y operaciones relevantes

Explicación: Los filtros de Procmon ayudan a aislar eventos entre el ruido del sistema.

Fuente: 08 Analisis_de_malware.pdf · pág. 54

327. ¿Qué clase de información es directamente observable con Procmon según la diapositiva?

Respuesta correcta: B) Operaciones sobre registro, archivos, red, procesos e hilos

Explicación: Procmon registra actividad de múltiples clases de eventos del sistema.

Fuente: 08 Analisis_de_malware.pdf · pág. 52

328. Se quiere inspeccionar la actividad de red de un proceso durante la ejecución de una muestra. ¿Qué herramienta de captura de paquetes aparece en clase?

Respuesta correcta: E) Wireshark

Explicación: Wireshark sirve para examinar tráfico observado en la red.

Fuente: 08 Analisis_de_malware.pdf · pág. 56

329. La muestra intenta consultar «ejemplo.invalido» mientras se analiza sin salida a Internet. ¿Qué herramienta indicada simula las consultas DNS?

Respuesta correcta: B) FakeDNS

Explicación: FakeDNS simula exclusivamente el manejo de consultas DNS.

Fuente: 08 Analisis_de_malware.pdf · pág. 56

330. Se necesitan respuestas sintéticas de varios servicios de red dentro de un laboratorio Windows. ¿Qué herramienta aparece en el material?

Respuesta correcta: A) FakeNet

Explicación: FakeNet emula servicios de Internet para observar comunicaciones de la muestra.

Fuente: 08 Analisis_de_malware.pdf · pág. 56

331. Una inspección dinámica muestra una consulta DNS, pero no se registró descarga posterior. ¿Qué conclusión es válida?

Respuesta correcta: B) Se observó una consulta; no está demostrada la descarga en ese experimento

Explicación: Hay que separar eventos observados de capacidades meramente hipotéticas.

Fuente: 08 Analisis_de_malware.pdf · pág. 56

332. La muestra tiene una URL en disco, pero al ejecutarla en el laboratorio no intenta conectarse. ¿Qué explica mejor la discrepancia?

Respuesta correcta: A) Una cadena estática no prueba que el flujo asociado se haya ejecutado

Explicación: El análisis estático plantea hipótesis; el dinámico revela acciones en una ejecución.

Fuente: 08 Analisis_de_malware.pdf · pág. 35

333. Se desea estudiar los procesos activos y su comportamiento luego de ejecutar una muestra. ¿Qué alternativa aparece en los apuntes?

Respuesta correcta: C) Process Explorer / Process Hacker

Explicación: Las herramientas de inspección de procesos permiten observar información del proceso.

Fuente: 08 Analisis_de_malware.pdf · pág. 57

334. Un analista compara strings presentes en el archivo con strings observables en memoria tras ejecutarlo. ¿Qué beneficio puede conseguir?

Respuesta correcta: B) Encontrar cadenas que no eran visibles en el archivo en reposo

Explicación: Los apuntes señalan explícitamente la comparación entre cadenas de memoria y de disco.

Fuente: 08 Analisis_de_malware.pdf · pág. 57

335. Una muestra realiza cambios de registro pero el analista solo revisa conexiones con Wireshark. ¿Qué evidencia es posible que no capture?

Respuesta correcta: B) La creación de valores persistentes en el registro de Windows

Explicación: El tráfico de red no sustituye la inspección de cambios locales de registro.

Fuente: 08 Analisis_de_malware.pdf · pág. 48

336. Una muestra escribe una entrada de inicio en HKCU pero no crea servicio. ¿Qué diferencia operativa se desprende del apunte?

Respuesta correcta: E) La persistencia bajo HKCU puede no necesitar privilegios de administrador

Explicación: La diapositiva contrasta permisos de HKCU con rutas que requieren administración.

Fuente: 08 Analisis_de_malware.pdf · pág. 43

337. Se analiza una muestra que incluye iconos aparentemente legítimos y recursos incrustados. ¿Qué precaución es razonable?

Respuesta correcta: C) Un recurso visual legítimo no demuestra que el ejecutable sea seguro

Explicación: Los recursos son una fuente de información, no evidencia suficiente de legitimidad.

Fuente: 08 Analisis_de_malware.pdf · pág. 21

338. Se reciben dos muestras con distinto nombre pero el mismo hash y tamaño. ¿Qué criterio de identificación resulta más fuerte?

Respuesta correcta: C) El digest calculado sobre el contenido, no el nombre de archivo

Explicación: Los hashes sirven para identificar muestras por contenido y no por su nombre.

Fuente: 08 Analisis_de_malware.pdf · pág. 4

339. Una muestra empaquetada presenta notables diferencias entre tamaño en disco y tamaño en memoria de una sección. ¿Cómo se utiliza ese hallazgo?

Respuesta correcta: E) Como indicio que justifica investigar empaquetamiento

Explicación: Las diferencias entre tamaños raw y virtual aparecen entre los indicios de packer.

Fuente: 08 Analisis_de_malware.pdf · pág. 29

340. Un binario importó una función sensible pero jamás se observó su ejecución. ¿Qué afirmación evita sobreinterpretar el hallazgo?

Respuesta correcta: B) La importación acredita una capacidad potencial, no una acción confirmada

Explicación: La tabla de imports revela capacidades, pero no reconstruye necesariamente una ejecución.

Fuente: 08 Analisis_de_malware.pdf · pág. 19

341. Una PC presenta una nueva entrada de registro Run y, además, se detecta un proceso sospechoso tras cada login. ¿Qué hipótesis relaciona ambos indicios?

Respuesta correcta: D) Persistencia mediante autoejecución al iniciar sesión

Explicación: Las Run keys disparan programas al autenticarse el usuario.

Fuente: 08 Analisis_de_malware.pdf · pág. 44

342. ¿Por qué conviene realizar capturas y guardado de evidencias antes de restaurar el snapshot de una VM?

Respuesta correcta: C) Para conservar indicadores y cambios observados que desaparecerían al restaurarla

Explicación: La metodología compara estado antes y después y restaura el entorno para nuevas pruebas.

Fuente: 08 Analisis_de_malware.pdf · pág. 40

343. Se identifica una muestra que registra pulsaciones y transmite los datos a un servidor remoto. ¿Qué indicador sería útil para buscar otras máquinas afectadas?

Respuesta correcta: B) La dirección o dominio de destino de las conexiones

Explicación: IP, URL y consultas DNS son indicadores de compromiso explícitos.

Fuente: 08 Analisis_de_malware.pdf · pág. 4

344. En un entorno de análisis aparece un archivo adicional con un ejecutable descargado por la muestra. ¿Qué es necesario registrar?

Respuesta correcta: C) La ruta y el hash del archivo creado como posibles IOC

Explicación: Los archivos creados y sus hashes ayudan a detectar otras instalaciones infectadas.

Fuente: 08 Analisis_de_malware.pdf · pág. 4

345. Un grupo de equipos muestra el mismo servicio extraño después de un incidente. ¿Qué característica puede incorporarse como IOC?

Respuesta correcta: E) Nombre y configuración del servicio creado

Explicación: Los servicios creados por malware pueden permitir identificar otras máquinas afectadas.

Fuente: 08 Analisis_de_malware.pdf · pág. 4

346. ¿Qué diferencia existe entre identificar una muestra por hash y atribuirla a una persona?

Respuesta correcta: E) Un hash distingue contenido; no acredita por sí solo la identidad del atacante

Explicación: Los IOC describen evidencias del malware, no autoría personal.

Fuente: 08 Analisis_de_malware.pdf · pág. 4

347. Un analista registra solo los procesos creados, sin tráfico ni archivos. ¿Qué limitación tiene su informe?

Respuesta correcta: C) Puede omitir indicadores y efectos en registro, filesystem o conexiones de red

Explicación: La metodología pide observar varios tipos de cambios en el sistema.

Fuente: 08 Analisis_de_malware.pdf · pág. 48

348. Se quieren observar posibles conexiones salientes sin exponer redes reales. ¿Qué estrategia se ajusta a los apuntes?

Respuesta correcta: B) Mantener el laboratorio aislado y simular servicios con FakeNet/FakeDNS

Explicación: El material combina aislamiento con servicios simulados para observar el comportamiento.

Fuente: 08 Analisis_de_malware.pdf · pág. 38

349. Una muestra tiene un import de CreateService, pero la inspección dinámica confirma solo una Run key HKCU. ¿Qué conclusión describe exclusivamente evidencia observada?

Respuesta correcta: D) Se configuró una entrada Run; no se demostró creación de servicio

Explicación: La evidencia dinámica comprobada es una Run key; una importación aislada no prueba uso real.

Fuente: 08 Analisis_de_malware.pdf · pág. 43

350. Un malware modifica el archivo hosts y valores de inicio automático. ¿Qué conjunto de fuentes es más apropiado para documentar ambos cambios?

Respuesta correcta: C) Comparación del filesystem y del registro antes y después

Explicación: Los cambios del sistema de archivos y de la registry son ámbitos del análisis dinámico.

Fuente: 08 Analisis_de_malware.pdf · pág. 35